

From Vulnerabilities to Remediation: A Systematic Literature Review of LLMs in Code Security

ENNA BASIC, Department of Computer Science, Orebro University, Sweden and Epiroc Rock Drills, Sweden
ALBERTO GIARETTA, Department of Computer Science, Orebro University, Sweden

Large Language Models (LLMs) have emerged as powerful tools for automating various programming tasks, including security-related ones, such as detecting and fixing vulnerabilities. Despite their promising capabilities, when required to produce or modify pre-existing code, LLMs could introduce vulnerabilities unbeknown to the programmer. When analyzing code, they could miss clear vulnerabilities or signal nonexistent ones. In this Systematic Literature Review (SLR), we aim to investigate both the security benefits and potential drawbacks of using LLMs for a variety of code-related tasks. In particular, first we focus on the types of vulnerabilities that could be introduced by LLMs, when used for producing code. Second, we analyze the capabilities of LLMs to detect and fix vulnerabilities, in any given code, and how the prompting strategy of choice impacts their performance in these two tasks. Last, we provide an in-depth analysis on how data poisoning attacks on LLMs can impact performance in the aforementioned tasks.

CCS Concepts: • **Security and privacy** → **Software security engineering; Vulnerability scanners**; • **Computing methodologies** → *Artificial intelligence*.

Additional Key Words and Phrases: Large Language Models, LLMs, Security Vulnerabilities, LLM-generated Code, Vulnerability Detection, Vulnerability Fixing, Prompt Engineering, Data Poisoning

Enna Basic and Alberto Giaretta. 1, 1 (April 2025), 35 pages. <https://doi.org/10.1145/nnnnnnnn.nnnnnnnn>

1 Introduction

Large Language Models (LLMs) are Machine Learning (ML) models designed for natural language processing [18]. Representative models such as ChatGPT [5], Llama [99], GitHub Copilot [6], and BERT [47] have gained extreme popularity and recognition in the last couple of years due to their ability to perform well across different tasks.

Among other capabilities, LLMs effectively translate natural language into code, assist in code comprehension, and answer questions related to code [46]. Many developers utilize these abilities to optimize coding processes, reducing development time and thereby improving productivity. According to GitHub statistics, GitHub Copilot is now responsible for generating approximately 46% of code and boosts developers' coding speed by up to 55% [29]. In addition to their coding skills, LLMs can be powerful tools for vulnerability detection and fixing, particularly when provided with detailed prompts and clear background information [52, 122].

While LLMs represent an advancement in code generation, they exhibit several limitations that pose security risks. One concern is that, despite their proficiency in producing functional code, LLMs often lack awareness and understanding of secure coding practices [42, 68]. Another concern is that LLMs are trained on enormous datasets, often gathered from unverified online platforms (e.g., GitHub [3] and HuggingFace [4]). This reliance on potentially insecure data introduces data poisoning risks, where an attacker inserts harmful data samples into

Authors' Contact Information: Enna Basic, Department of Computer Science, Orebro University, Orebro, Sweden and Epiroc Rock Drills, Orebro, Sweden; Alberto Giaretta, Department of Computer Science, Orebro University, Orebro, Sweden.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

© 2025 Copyright held by the owner/author(s). Publication rights licensed to ACM.

ACM XXXX-XXXX/2025/4-ART

<https://doi.org/10.1145/nnnnnnnn.nnnnnnnn>

the training set [25]. These and other shortcomings can lead LLMs to generate insecure code, as well as influence their abilities to detect and fix security vulnerabilities.

Regardless of the risks, LLMs are largely used for their code-related capabilities. Therefore, to take informed decisions, it is crucial for practitioners to have a clear understanding about the precise nature of risks and benefits. In this Systematic Literature Review (SLR), we aim to:

- Explore the potential security vulnerabilities introduced by LLM-generated code;
- Evaluate the effectiveness of LLMs in detecting and fixing vulnerabilities, as well as the prompting strategies used for these tasks;
- Investigate the effects of data poisoning on LLMs ability to produce secure code and to detect and fix vulnerabilities effectively.

1.1 Outline

This paper is organized as follows. Section 2 describes related works. Section 3 describes the methodology we have followed in this work. Section 4 discusses the vulnerabilities identified in LLM-generated code, by the state of the art. Section 5 examines LLMs ability to detect code vulnerabilities, Section 6 their ability to fix pre-identified vulnerabilities, and Section 7 their potential to detect and fix vulnerabilities in a unified process. Furthermore, Section 8 covers prompting techniques used for vulnerability detection and fixing, as described by the studies covered in this review. Section 9 explores the impact of poisoned training data on LLMs ability to generate secure code, detect vulnerabilities, and fix them. Section 10 addresses the research questions, open challenges, and threats to validity. Finally, Section 11 concludes the paper.

2 Related Work

While the Introduction outlined the key themes and goals of our survey, this section reviews related work and outlines how our survey builds on and extends previous efforts.

In recent years, several literature reviews have focused on different aspects of the intersection between LLMs and code security. As we discussed in Section 1, in this SLR we focus on three main thematic areas. Although other surveys have covered these areas, all of them focused on only one (or two) areas at a time. To the best of our knowledge, this is the first comprehensive survey that addresses all three areas. Furthermore, this is the first paper that attempts to categorize the different vulnerabilities that could be introduced by LLMs. For instance, Negri et al. [69] conducted an SLR to explore the impact of AI models on software security, finding that LLMs often generate code containing specific vulnerabilities, but they did not provide a systematic categorization. Extending their work, we organize the vulnerabilities introduced by LLM-generated code, into ten distinct categories. Besides, we analyze quantitatively their prevalence across studies, highlighting less explored areas.

Other characteristics differentiate our paper from the current literature. First, while other surveys have investigated the performance of LLMs for vulnerability detection and fixing, unified processes for addressing both tasks have not been surveyed. Second, no other survey investigates how the prompting strategy of choice impacts tasks related to code security.

Yao et al. [110] reviewed various applications of LLMs in security, including vulnerability detection and fixing. However, their work did not investigate the impact of prompting techniques on such tasks, nor the merging of vulnerability detection and fixing in a unified process. Zhou et al. [119] provided an overview of prompting techniques, listing which papers applied each technique for vulnerability detection and repair. Unlike their work, we focus on how each prompting technique impacts LLMs effectiveness in these tasks.

Furthermore, the literature does not cover the impact of data poisoning attacks on LLMs code generation, and our work fills this gap by analyzing this potential impact. Even though data poisoning attacks are explored by Yao et al. [110], the paper does not discuss the effects of these attacks on LLMs secure code generation, nor

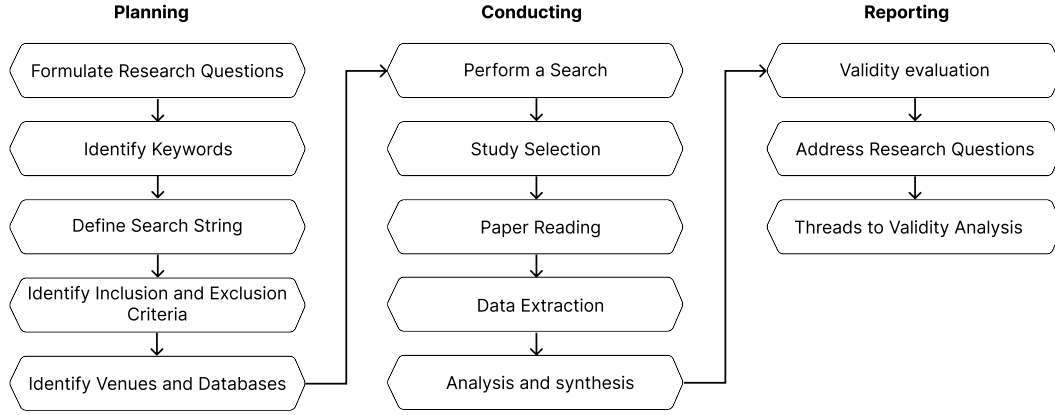


Fig. 1. Systematic literature review methodology.

on vulnerability-related tasks. Chen et al. [22] reviewed defenses and attacks targeting LLMs used for code generation, highlighting the general impact of such attacks. Although they also discussed the consequences of poisoning attacks on secure code generation, this was not the main focus of their paper. For example, they also explored the effects on tasks unrelated to security, including code summarization and code search. In contrast, we provide an in-depth exploration of security-specific aspects, discussing how poisoning attacks influence the ability of LLMs to generate secure code, detect vulnerabilities, and propose fixes.

A few relevant studies conducted broader literature reviews extending beyond code security. Xu et al. [106] examined LLM applications across multiple cybersecurity tasks, including vulnerability detection, malware analysis, network intrusion detection, and phishing detection. Hou et al. [44] reviewed the use of LLMs in software engineering, including, but not limited to, code security. They noted that code generation and program repair are the most common applications in software development and maintenance. Finally, Zhang et al. [113] focused on methodologies for constructing LLMs, specifically designed for cybersecurity tasks.

3 Methodology

In this study, we conducted an SLR following the well-established guidelines proposed by Petersen et al. [84]. Our methodology, illustrated in Figure 1, includes three main phases: Planning, Conducting, and Reporting. In the remainder of this section, we detail the Planning phase.

3.1 Research Questions

We formulated the following Research Questions (RQs) to guide our investigation and help fulfill the aims of this study:

- **RQ1:** What security vulnerabilities could be introduced by LLM-generated code?
- **RQ2:** To what extent can LLMs detect and fix vulnerabilities, in both human-written and LLM-generated code?
 - **RQ2.1:** How do different prompting techniques impact the effectiveness of LLMs in detecting and fixing code vulnerabilities?
- **RQ3:** How does the poisoning of training datasets impact the LLMs ability of producing secure code, detecting and fixing vulnerabilities?

3.2 Search Strategy

Based on our RQs, we have identified 5 sets of keywords, which we later used to define our search strings:

- **Set 1:** Large Language Models, Language Model, LLMs, CodeX, Llama, Copilot, GPT-*, ChatGPT.
- **Set 2:** Code Generation, AI-generated Code, Automated Code Generation.
- **Set 3:** Security Vulnerabilities, Security Risks, Security Flaws, Security Implications, Software Security, Impact On Code Security, Cybersecurity, Vulnerabilities.
- **Set 4:** Training Data Poisoning, Poisoned Datasets, Data Poisoning Attacks, Adversarial Attacks, Malicious Training Data.
- **Set 5:** Vulnerability Detection, Bug Detection, Security Flaw Detection, Code Analysis, Static Analysis, Vulnerability Remediation, Bug Fixing, Automated Code Repair, Security Patch, Code Patching.

Based on these sets of keywords, we developed the following search strings to perform an automated database search. The first search string is designed to address RQ1:

("Large Language Models" OR "Language Model" OR "LLMs" OR CodeX OR Llama OR Copilot OR GPT-* OR ChatGPT) AND ("Security Vulnerabilities" OR "Security Risks" OR "Security Flaws" OR "Software Security" OR "Impact On Code Security" OR Cybersecurity OR Vulnerabilities) AND ("Code Generation" OR "AI-generated Code" OR "Automated Code Generation").

The second search string is designed to address RQ2:

("Large Language Models" OR "Language Model" OR CodeX OR Llama OR Copilot OR GPT-* OR ChatGPT) AND ("Vulnerability Detection" OR "Bug Detection" OR "Security Flaw Detection" OR "Code Analysis" OR "Static Analysis" OR "Vulnerability Remediation" OR "Bug Fixing" OR "Automated Code Repair" OR "Security Patch" OR "Code Patching").

Finally, the third search string is designed to address RQ3:

("Large Language Models" OR "Language Model" OR LLMs OR CodeX OR Llama OR Copilot OR GPT-* OR ChatGPT) AND ("Code Generation" OR "AI-generated Code" OR "Automated Code Generation") AND ("Security Vulnerabilities" OR "Security Risks" OR "Security Flaws" OR "Software Security" OR "Impact On Code Security" OR "Cybersecurity" OR Vulnerabilities) AND ("Training Data Poisoning" OR "Poisoned Datasets" OR "Data Poisoning Attacks" OR "Adversarial Attacks" OR "Malicious Training Data") AND ("Vulnerability Detection" OR "Bug Detection" OR "Security Flaw Detection" OR "Code Analysis" OR "Static Analysis" OR "Vulnerability Remediation" OR "Bug Fixing" OR "Automated Code Repair" OR "Security Patch" OR "Code Patching").

3.3 Selection Criteria

To ensure a relevant review of the literature, we defined specific inclusion and exclusion criteria. We designed the inclusion criteria to make sure the selected papers meet certain standards and relevance, while exclusion criteria help us eliminate papers that do not fit the research objectives or quality standards. The detailed criteria for paper selection are outlined in Table 1.

Given that the field is relatively new and has seen significant contributions in the last few years, we did not establish criteria for narrowing down the period of publications. For the same reason, we also include non-peer-reviewed papers, such as those from arXiv, to ensure that we capture the most recent and significant developments in the field.

Table 1. Inclusion and exclusion criteria for paper selection.

Inclusion Criteria
IN1: The title and abstract of the paper include the keywords. IN2: Complete papers retrieved from searches in the IEEE Xplore Digital Library, ACM Digital Library, ScienceDirect, or SpringerLink as well as preprints available on arXiv. IN3: Papers that specifically identify vulnerabilities in code generated by LLMs. IN4: Papers that evaluate the capability of LLMs to identify and fix security vulnerabilities in code. IN5: Papers that explore the impact of the poisoned training data of LLMs on security and their ability to detect and fix vulnerabilities.
Note: To be included in the review, a paper must satisfy IN1 and IN2, and (IN3 or IN4 or IN5).
Exclusion Criteria
EX1: Papers not written in English. EX2: Articles without accessible full-text versions. EX3: Secondary studies, such as SLRs or surveys. EX4: Papers that focus on LLM capabilities unrelated to security. EX5: Duplicate studies or reviews that do not offer new insights or data compared to already included papers.

4 Security Vulnerabilities Introduced by LLMs

Although LLMs became popular for their ability to generate functional code fast and speed up development, they can introduce security vulnerabilities that developers might miss, leading to risks regarding code integrity and safety [42]. In this section, we focus on specific vulnerabilities introduced by LLM-generated code, as identified through various studies we have analyzed in this paper.

In total, we have identified 20 papers that discuss vulnerabilities in LLM-generated code. We have collected the vulnerabilities highlighted in each paper, and organized them in 10 categories, shown in Table 2. In this table, we indicate with a green checkmark (✓) whether a vulnerability was identified in the study.

Before delving into a detailed exploration of each category, we think it is worth analyzing how often these categories are discussed, throughout the 20 papers. As shown in Figure 2, the attention that has been given by the various authors to the different categories, is fairly distributed, with a few categories deemed more critical than others. For example, injection vulnerabilities are covered in 16 out of 20 studies, while error handling vulnerabilities are discussed in 3 studies.

Most of these studies identified vulnerabilities using the Common Weakness Enumeration (CWE) [65], with the corresponding CWE numbers listed in Table 3. Many of these vulnerabilities are included in MITRE '2023 CWE Top 25 Most Dangerous Software Weaknesses' list [66], while others are referenced indirectly through related child CWEs.

4.1 Injection Vulnerabilities

Injection vulnerabilities are identified across most of the reviewed studies, appearing in 16 papers. This category contains various types of vulnerabilities, including SQL injection, Cross-Site Scripting (XSS), OS command injection, and regular expression (regex) injection.

Two studies focused extensively on injection vulnerabilities. Khoury et al. [48] conducted an experiment where they generated 21 programs in 5 different programming languages using ChatGPT 3.5. The programs were

Table 2. Vulnerabilities introduced by LLM generated code identified in the studies.

References	Injection	Memory Management	File Management	Deserialization	Sensitive Data Exposure	Authentication and Authorization	Cryptography	Resource Management	Coding Standards	Error Handling
Liu et al. [61]	✓	✓	✓	✓	✓	✓				
Khoury et al. [48]	✓	✓	✓		✓	✓	✓			
Asare et al. [9]	✓					✓		✓	✓	
Perry et al. [83]	✓	✓	✓			✓	✓			
Sandoval et al. [87]		✓						✓		✓
Pearce et al. [80]	✓	✓	✓		✓	✓				
Elgedawy et al. [30]	✓				✓	✓			✓	✓
Siddiq et al. [90]	✓				✓	✓	✓			
Hajipour et al. [39]	✓	✓	✓							
Kim et al. [49]		✓						✓	✓	
He et al. [42]	✓	✓	✓							
Siddiq et al. [91]	✓	✓	✓	✓		✓	✓			
Tóth et al. [98]	✓		✓							
Tihanyi et al. [97]		✓		✓					✓	
Hamer et al. [40]						✓	✓	✓		
Rabbi et al. [86]	✓			✓		✓	✓	✓		✓
Fu et al. [35]	✓		✓		✓		✓	✓	✓	
He et al. [43]	✓	✓	✓	✓	✓	✓	✓			
Mohsin et al. [68]	✓		✓		✓		✓	✓		
Gong et al. [37]	✓		✓	✓	✓	✓	✓	✓	✓	
Total number of studies	16	11	12	6	9	12	10	8	6	3

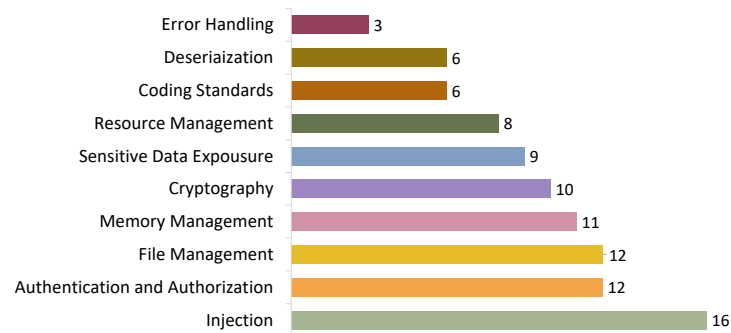


Fig. 2. Bar chart showing the number of studies discussing each category of security vulnerabilities introduced by LLMs.

intentionally diverse, each designed to highlight the risks associated with specific vulnerabilities. Among these, 6 programs specifically targeted injection vulnerabilities. Notably, in every instance, ChatGPT 3.5 failed to do proper input sanitization, resulting in various types of injection vulnerabilities. Similarly, Tóth et al. [98] focused on the security of 2500 PHP websites, generated by GPT-4. Using both dynamic and static scanners, manual code

Table 3. Studies and the CWE Numbers.

References	CWE number
Liu et al. [61]	20, 22, 78, 79, 89, 119, 125, 190, 200, 206, 416, 434, 476, 502, 522, 787, 798
Khoury et al. [48]	35, 94, 133, 190, 256, 323, 338, 377, 400, 453, 502, 564, 687, 759
Asare et al. [9]	284, 664, 682, 691, 707, 710
Sandoval et al. [87]	252, 401, 416, 476, 758, 787
Pearce et al. [80]	20, 22, 77, 78, 79, 89, 119, 125, 190, 200, 306, 416, 434, 476, 522, 787, 798
Siddiq et al. [90]	79, 208, 209, 215, 287, 295, 312, 338, 798, 918
Hajipour et al. [39]	20, 22, 79, 190, 787
Kim et al. [49]	75, 119, 197, 401, 457, 467, 476, 562, 685, 686, 758, 788
He et al. [42]	22, 78, 79, 89, 125, 190, 476, 787
Siddiq et al. [91]	20, 22, 79, 89, 94, 297, 352, 327, 502, 601, 611, 730
Tóth et al. [98]	20, 80, 83
Tihanyi et al. [97]	120, 129, 190, 191, 476, 628, 761, 787, 788, 843
Hamer et al. [40]	327, 328, 404, 772, 798
Rabbi et al. [86]	20, 78, 94, 259, 327, 330, 400, 502, 605, 703
Fu et al. [35]	22, 78, 89, 94, 117, 215, 295, 312, 367, 369, 502, 563, 617, 628, 772, 798
He et al. [43]	22, 79, 89, 119, 200, 295, 326, 327, 338, 352, 502, 611, 732, 915
Mohsin et al. [68]	20, 22, 89, 200, 352, 676, 759
Gong et al. [37]	22, 78, 79, 80, 90, 94, 95, 99, 113, 116, 117, 200, 209, 215, 250, 252, 259, 269, 283, 285, 319, 321, 326, 329, 330, 331, 367, 377, 385, 400, 406, 414, 425, 434, 454, 462, 502, 522, 595, 601, 605, 611, 641, 643, 732, 759, 760, 776, 798, 827, 841, 918, 941, 943, 1204

verification, and penetration testing, they identified various vulnerabilities, particularly concerning the security of file upload functions, as well as SQL injections and XSS.

The studies frequently identified the following injection-related CWEs: CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') [37, 39, 42, 43, 61, 80, 90, 91], and CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') [35, 42, 43, 61, 68, 80, 91].

4.2 Memory Management

This category includes vulnerabilities related to memory management, identified across most of the included studies. These vulnerabilities include overflow vulnerabilities, such as buffer and integer overflow, mostly caused by the lack of input sanitization. Moreover, this category includes null pointer dereference and use-after-free memory allocation vulnerabilities. These issues arise due to improper handling of memory references and pose significant risks to system security. Although [39, 42, 43, 48, 49, 61, 80, 83, 87, 91, 97] all identified memory vulnerabilities in code produced by LLMs, Liu et al. [61] placed special importance on memory management vulnerabilities. They performed a systematic empirical assessment of the quality of code generated using ChatGPT, by solving 728 algorithmic problems. Their study highlighted significant issues in memory management within

LLM-generated code. Specifically, they found that the majority of vulnerabilities were related to missing null pointer tests, with 91.8% of the total vulnerabilities attributed to the MissingNullTest query. These code snippets failed to check for null after memory allocation, which can lead to critical security vulnerabilities such as CWE-476: Null pointer dereference, also identified in [49, 80, 87, 97].

In addition to null pointer dereference, other frequently identified CWEs related to memory management are: CWE-190: Integer Overflow or Wraparound [39, 42, 48, 61, 80, 97], and CWE-416: Use After Free [61, 80, 87].

4.3 File Management

File management vulnerabilities are mostly caused by improper handling of files and directories. These vulnerabilities can lead to **unauthorized access, data corruption, or system compromise**. The most common file management vulnerabilities include **improper path restrictions, unrestricted file uploads, and insecure file permissions**. Several studies have identified file management vulnerabilities in LLM-generated code [35, 35, 37, 39, 43, 48, 61, 80, 83, 91, 98]. However, He et al. [42], and Mohsin et al. [68] dedicated more focus to these vulnerabilities, finding that LLMs often produce code that does not properly restrict file paths based on user input, potentially allowing unauthorized file access. This vulnerability is marked as CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') [35, 37, 39, 43, 61, 68, 80, 91].

4.4 Deserialization

Deserialization vulnerabilities happen when untrusted data is used to reconstruct objects within an application. These vulnerabilities can lead to **arbitrary code execution, data manipulation, or denial-of-service attacks**. These vulnerabilities are especially concerning in systems that use serialization for communication or storage, as they can be exploited if proper validation and sanitization are not implemented. The primary CWE associated with this issue is: CWE-502: Deserialization of Untrusted Data [37, 43, 61, 86, 91].

Several studies have recognized deserialization vulnerabilities [37, 43, 61, 86, 91, 97], however, none of them specifically focused on this topic, leaving some open questions for further research. For example, how frequently do LLMs generate insecure code when prompted with tasks targeting deserialization vulnerabilities?

4.5 Sensitive Data Exposure

Sensitive data Exposure occurs when critical information, such as personal data, financial details, or authentication credentials, are not properly protected and become accessible to unauthorized entities. Sensitive data exposure is often caused by ineffective data encryption, insecure storage, or flaws in data transmission protocols.

Several studies have recognized the exposure of sensitive data in the code generated by LLMs [30, 35, 37, 43, 48, 61, 68, 90]. However, Pearce et al. [80] dedicated more attention to this category of vulnerabilities. They studied how frequently and why GitHub Copilot generates insecure code by testing it with 89 different scenarios related to high-risk cybersecurity vulnerabilities. Besides from finding that approximately 40% of these programs were vulnerable, they showed that Copilot consistently fails when it comes to CWE-200: Exposure of Sensitive Information to an Unauthorized Actor. The same CWE was also mentioned in [37, 43, 61, 68]. A concrete example of how Copilot-generated code exhibits a CWE-200 vulnerability can be found with Python web apps [80]. In some cases, although the app is supposed to display only the last 4 digits of a Social Security Number (SSN), it happened that it revealed more digits than expected.

4.6 Authentication and Authorization

Authentication and authorization vulnerabilities represent a significant category of security issues, highlighted in 12 out of 20 studies. **Authentication** vulnerabilities occur when a system fails to properly verify the identity of users or devices. This kind of vulnerability is mostly caused by weak password requirements, insufficiently

protected credentials, or the use of hard-coded credentials. Hamer et al. [40] compared the security properties of the code generated by ChatGPT, with answers provided in Stack Overflow. They concluded that ChatGPT-generated code had 20% fewer vulnerabilities than Stack Overflow snippets, although both produced security flaws. One of the most frequent CWES in both ChatGPT-generated code and Stack Overflow snippets was CWE-798: Use of Hard-coded Credentials. CWE-798 is also discussed in [37, 61, 80, 90].

Authorization vulnerabilities arise when a system fails to properly enforce access control policies, which allows users or processes to perform actions beyond their intended permissions. This vulnerability is often caused by improper implementation of access control. The associated CWE is CWE-284: Improper Access Control, as discussed by Asare et al. [9], who conducted a comparative empirical analysis of Copilot-generated code, showing that GitHub Copilot is less likely to produce vulnerable code, compared to human developers.

4.7 Cryptography

Cryptographic vulnerabilities arise when encryption mechanisms are poorly implemented or completely absent. Common causes of weak encryption include the use of broken or insecure cryptographic algorithms, improper validation of certificates, the use of weak or absent hashing functions, and the reuse or hard-coding of cryptographic keys. Several studies [35, 37, 40, 43, 48, 68, 86, 90, 91] identified cryptographic weaknesses in LLM-generated code, without exploring them in detail.

Perry et al. [83] studied how users interact with AI code assistants to solve security-related tasks. The study found that participants with access to an AI assistant were more likely to produce incorrect and insecure solutions, compared to a control group. Specifically, in one cryptography-related task, participants with AI assistance were significantly more likely to use trivial ciphers or fail to authenticate the final output.

A common cryptographic vulnerability identified in multiple studies is CWE-327: Use of a Broken or Risky Cryptographic Algorithm [40, 43, 86, 91].

4.8 Resource Management

Resource Management vulnerabilities refer to weaknesses in the handling, allocation, and release of system resources that are not strictly related to memory or file systems. These vulnerabilities were also identified across multiple studies as improper control of resources, resource leaks, and improper resource shutdowns.

Hamer et al. [40] identified two prevalent resource management vulnerabilities in ChatGPT-generated code: CWE-404: Improper Resource Shutdown or Release, and CWE-772: Missing Release of Resource after Effective Lifetime. Both CWEs were tied as the second most frequent vulnerabilities, each appearing in 37, out of 216 code snippets. Other studies also highlighted related vulnerabilities, including CWE-605: Multiple Binds to the Same Port [37, 86], and CWE-664: Improper Control of a Resource Through its Lifetime [9].

In general, resource management vulnerabilities were identified by [9, 35, 37, 49, 68, 86, 87], however, none of these studies explored in depth the resource management vulnerabilities in LLM generated-code.

4.9 Coding Standards

This vulnerability category includes issues arising when software development practices do not adhere to established standards, leading to inconsistent, unreliable, or insecure code. Such deviations can introduce unexpected bugs, security flaws, or system crashes. Common vulnerabilities of this type include logical errors, such as division by zero and incorrect calculations, as well as issues with function calls, such as incorrect number of arguments or incorrect argument types.

Tihanyi et al. [97] conducted a comparative analysis of LLMs to examine how likely they are to generate vulnerabilities when writing simple C programs. They identified division by zero as a frequent issue in the code produced by LLMs, along with the challenges in managing arrays and arithmetic operations.

Additionally, CWE-758: Reliance on Undefined, Unspecified, or Implementation-Defined Behavior is another significant concern discussed in by Kim et al. [49], and Sandoval et al. [87]. Besides the mentioned studies, others have focused on this type of vulnerability, but without exploring it in detail, as can be seen in [9, 30, 35, 37].

4.10 Error Handling

Error handling vulnerabilities arise when a system or application fails to properly manage exceptional conditions. Poor error handling can lead to a variety of issues, including security vulnerabilities, system crashes, or unreliable software behavior. One common issue in error handling is the failure to check or handle return values from functions or system calls properly. A few studies focused on error handling vulnerabilities [30, 86, 87], however, none of these studies specifically addressed this category of vulnerabilities, which presents another topic for future research. Among the various CWS, CWE-703: Improper Check or Handling of Exceptional Conditions has been specifically highlighted in the literature as a notable issue [86].

4.11 LLMs in Code Generation: Balancing Risks and Benefits

As we have described throughout this section, LLMs often produce code with security vulnerabilities [30, 35, 83, 90, 97, 98]. Interestingly, when ChatGPT fixes human-written code, the revised version often contains more security vulnerabilities compared to code generated from scratch by ChatGPT [86].

Despite these challenges, LLMs remain valuable tools in coding tasks. Research indicates that code generated by ChatGPT generally introduces fewer CWE issues compared to code found on Stack Overflow [40]. Moreover, LLMs do not significantly increase the incidence rates of severe security bugs [87], and tools like GitHub Copilot have been shown to produce code with fewer security vulnerabilities than code written by human developers [9].

Even though LLMs may generate vulnerable code, the literature suggests that using more effective prompts can guide them to produce safer code [48, 61]. Through improved re-prompting, the security issues initially present in LLM-generated code can often be addressed, making LLMs valuable tools for creating secure code, when used appropriately. This topic will be explored more in details in Section 7.

5 LLMs for Vulnerability Detection

While LLMs can introduce vulnerabilities into the code they generate, the same models also offer opportunities to improve software security, particularly through their use in vulnerability detection.

Security code reviews performed manually require significant time and effort, especially in large-scale open-source projects with large numbers of contributions. Hence, the automated tools able to identify security vulnerabilities during code review are highly beneficial [79]. Among these tools, LLMs emerged as a promising solution for detecting security vulnerabilities.

This section explores the effective use of LLMs for detecting vulnerabilities in code, in particular, we highlight their limitations, compare their performance with traditional methods, and examine the potential of fine-tuning to enhance their effectiveness in this task.

5.1 Uses of LLMs for Vulnerability Detection

Despite the growing interest in exploiting LLMs for vulnerability detection, their specific capabilities and performance in real-world scenarios require a deeper exploration.

The work by Mohajer et al. [67] demonstrated the ability of ChatGPT to perform static bug detection and false positive warning removal. The evaluation focused on two critical types of bugs often targeted by Static Analysis Tools (SATs): Null Dereference and Resource Leak. For detecting Null Dereference, ChatGPT achieved around 68% accuracy and 64% precision, and for detecting Resource Leak, about 77% accuracy and 83% precision.

Concerning false-positive warning removal, ChatGPT reached around 94% precision for Null Dereference bugs and 63% for Resource Leak bugs.

Thapa et al. [96] empirically evaluated the performance of several transformer-based language models for software vulnerability detection. The authors presented a framework that allows for translating C/C++ source code into vectorized inputs, a format suitable for vulnerability analysis. The authors tested various models on software vulnerability datasets, and found that, concerning Buffer Errors and Resource Management Errors, GPT-2 Large and GPT-2 XL achieved the highest F1-score of all the models, with 95.51% and 95.40%, respectively.

A study by Zhang et al. [115] focused on LLMs capabilities for automated vulnerability detection. They tested over 10 different LLM models using various techniques like zero-shot and one-shot learning (for more details on prompting techniques, we refer the reader to Section 8), and fine-tuning. They applied these models to various datasets of source code, exhibiting C/C++ and smart contract vulnerabilities. The best performing model, CodeLlama-7B, achieved the highest F1-score of 82% with discriminative fine-tuning, along with a precision of approximately 89% and a recall of around 78%.

According to Wen et al. [103], existing pre-trained models for vulnerability detection often miss important details and struggle with complex code. As a consequence, performing accurate vulnerability detection can be difficult. To address this, Wen et al. [103] proposed a Structured Natural Language Comment tree-based Vulnerability Detection framework, based on pre-trained models, named SCALE. This framework is composed of three main modules. The first module, Comment Tree Construction, helps the model understand code semantics, by incorporating LLMs for comment generation and adding the comment node to Abstract Syntax Trees (ASTs). The second module, Structured Natural Language Comment Tree Construction, refines this process by explicitly involving code execution sequences and combining code syntax templates with the comment tree. The third module, SCT-Enhanced Representation, uses these improved comment trees to capture vulnerability patterns and better understand vulnerabilities in the code. Results show that SCALE outperforms existing methods, including supervised, retrained model-based, and other LLM-based approaches in detecting vulnerabilities.

Omar et al. [77] proposed a Knowledge Distillation (KD) technique, designed to improve vulnerability detection. In KD, a smaller, simpler model (the “student”) learns to replicate the behavior of a larger, more complex model (the “teacher”). The goal is to achieve similar or even better performance with the smaller model [16]. They assessed the performance of the KD when applied to various classifiers, including LLMs such as GPT-2 and CodeBERT, as well as Recurrent Neural Network (RNN) models such as LSTM. They revealed that GPT-2 performed outstandingly, achieving an F1 score of 92.4% on the SARD dataset [17]. While GPT-2 and CodeBERT showcased promising results, it was evident that LSTM-based models still have certain limitations in the context of this application.

Wen et al. [104] highlighted that current methods and datasets focus on detecting intra-procedural vulnerabilities, those found within single functions, overlooking vulnerabilities occurring across multiple functions. To address this, they proposed VulEval, a repository-level evaluation system designed to evaluate both inter- and intra-procedural vulnerabilities. VulEval consists of three phases: the first detects intra-procedural vulnerabilities from code, the second retrieves the most relevant dependencies from call graphs, and the third detects inter-procedural vulnerabilities by incorporating these dependencies. Using VulEval over a large-scale dataset, which includes both intra- and inter-procedural vulnerabilities, they evaluated 19 detection methods: 4 program analysis-based methods, 2 supervised learning-based methods, 7 fine-tuning-based methods, and 6 prompt-based methods. Overall, incorporating vulnerability-related dependencies improved repository-level detection performance, over function-level detection.

5.2 Issues in Using LLMs for Vulnerability Detection

While LLMs show considerable promise for vulnerability detection, several challenges and limitations persist. In this section, we aim to unwrap the limitations highlighted by the literature. Table 4 summarizes the challenges

Table 4. Challenges in using LLMs for vulnerability detection identified in the studies

References	False Positives	Context Awareness	Complex Scenarios	Verbosity and Non-Compliance	Token Limits
Steenhoek et al. [92]	✓				
Happe et al. [41]	✓	✓			
Yu et al. [111]			✓	✓	
Ullah et al. [100]			✓		
Purba et al. [85]	✓		✓		
Liu et al. [60]			✓		
Ding et al. [27]	✓		✓		
Çetin et al. [19]	✓				
Pelofske et al. [82]	✓				
Chen et al. [21]	✓				✓
Sun et al. [94]		✓			
Gao et al. [36]			✓		
Zhang et al. [115]					✓
Li et al. [53]	✓				
Hu et al. [45]	✓				
Zhou et al. [121]	✓				
Tamberg et al. [95]	✓				
Total number of studies	11	2	6	1	2

faced by LLMs in detecting vulnerabilities in code, as identified by the reviewed studies. In this table, we indicate with a green checkmark (✓) which challenge was highlighted in which study. Notably, most studies focused on the prevalence of false positives, discussed in 11 papers. In contrast, the other three challenges were mentioned in only one or two studies out of 17.

False positives are one of the key challenges for LLMs, where the model incorrectly flags a non-existent vulnerability. Ding et al. [27] reported that commonly used benchmarks often overestimate model performance, with a state-of-the-art 7B model achieving a 68.26% F1 score on a popular dataset BigVul, but only a 3.09% on the dataset they proposed. Çetin et al. [19] found that GPT-4, despite being the top-performing model in their study, still had a false positive rate of 63%, with other models performing even worse, reaching up to 97%. Pelofske et al. [82] revealed that, while some models achieved high recall and precision rates (up to 100%) for certain vulnerability types, they still exhibited significant rates of false positives. Chen et al. [21] also noted that while ChatGPT was able to identify vulnerabilities in blockchain smart contracts, it struggled with precision, leading to false positives. Zhou et al. [121], Tamberg et al. [95], and Purba et al. [85] found that, although LLMs outperform traditional vulnerability detection approaches in identifying vulnerabilities, they also exhibit high false positive rates. We further discuss this aspect in Subsection 5.3.

Some works have looked into proposing solutions to address this challenge. Li et al. [53] noticed that LLMs often produce false positives when used as static code analyzers. To address this, they proposed a method that

prompts ChatGPT to summarize functions, breaking down tasks step by step and progressively refining results to improve accuracy. Their approach eliminated 16 out of 20 false positives. Hu et al. [45] addressed the false positives issue by proposing a framework called GPTLens, which splits the conventional one-stage detection into two phases: generation and discrimination. In this framework, an LLM plays a dual role. In the generation phase, it acts as the Auditor, aiming to generate a wide range of vulnerabilities to capture the correct ones. In the discrimination phase, it acts as the Critic, evaluating these vulnerabilities to reduce false positives. The results show that GPTLens significantly improves vulnerability detection.

Context awareness is another challenge that LLMs face when detecting vulnerabilities in code. Happe et al. [41] pointed out that hallucinations stem from a lack of contextual understanding and grounding. Sun et al. [94] addressed this issue by developing GPTScan, which enhances context awareness by combining GPT with static analysis techniques. GPTScan parses code, identifies potential vulnerabilities, and maps them to known types, significantly improving detection precision and recall.

Some researchers found that LLMs often struggle with **complex scenarios**, especially those involving real-world code. For instance, Yu et al. [111] reported that although GPT-4 outperformed other models in security code review, its performance remained limited in complex scenarios. Ullah et al. [100] also highlighted that LLMs, including advanced models like GPT-4, exhibited unpredictable responses and incorrect reasoning when identifying security vulnerabilities in real-world scenarios. Purba et al. [85] found that while LLMs could detect certain vulnerability patterns, they still could not surpass traditional tools in handling tasks such as SQL injection and buffer overflow detection. Liu et al. [60] developed a benchmark to assess LLMs on progressively difficult tasks. They revealed that LLMs perform well (over 80% accuracy) at simpler tasks, such as identifying and classifying vulnerabilities. However, their accuracy dropped (below 30%) when faced with more complex tasks, such as detecting the root causes of vulnerabilities across extensive codebases. Finally, Ding et al. [27] observed that LLMs are not able to meet the requirements of effective vulnerability detection in real-world scenarios.

Yu et al. [111] found that, while GPT-4 was effective in detecting security vulnerabilities and outperformed other models, it faced **verbosity and non-compliance** challenges. These issues emerge when the model occasionally provides overly detailed responses or fails to meet prompt requirements, respectively. Both issues can affect the quality and trustworthiness of responses, in general.

Chen et al. [21] discussed the challenge of **token limits** when using ChatGPT for identifying vulnerabilities in blockchain smart contracts, noting that GPT-4 and GPT-3.5 can effectively analyze up to 33 KB and 16 KB of code, respectively. To address such input length constraints, Zhang et al. [115] proposed a solution based on sliding windows that divide long sequences into overlapping sequences of tokens. In addition, they introduced a right-forward embedding strategy, which enhances context by making each token aware of subsequent tokens.

Despite the challenges we have highlighted, most of the studies we have covered agree that LLMs have the potential to be effective tools for static analysis, provided additional fine-tuning and context-aware enhancements.

5.3 Comparison of LLMs with Traditional Vulnerability Detection Approaches

LLMs have shown great promise in vulnerability detection, but it is essential to compare their performance against traditional approaches, such as SATs and other ML models, used in this field for many years. Some studies suggest that LLMs outperform state-of-the-art SATs and ML models in detecting vulnerabilities, while others disagree, highlighting a divide in current research on their comparative effectiveness.

Table 5, and Table 6 provide an overview of the different LLM models and traditional analysis tools that have been used in each study, for comparing performance. Table 5 lists the papers where LLMs showed better vulnerability detection capabilities than traditional approaches. In contrast, Table 6 highlights the papers where traditional approaches performed better, identifying a higher percentage of vulnerabilities. From the sheer number

of papers included in each table, it is clear that, in most literature works, LLMs showed greater potentiality in discovering security vulnerabilities.

According to Yu et al. [111], traditional code analysis tools, despite their long-standing use, often struggle with issues such as high false positive rates, limited input ranges, and poor scalability. In contrast, LLMs, particularly GPT-based models, provide higher detection rates, compared to contemporary SATs. While most studies suggest that LLMs outperform traditional approaches in vulnerability detection, LLMs often exhibit also high false positive rates. For instance, Purba et al. [85] found that LLMs achieved higher detection rates than SATs, but exhibited false positive rates exceeding 60%, compared to rates under 45% for SATs like Flawfinder [2] and Checkmarx [1].

Building on this, Zhou et al. [121] found that LLMs can detect up to 100% of code vulnerabilities, but they often produce false positive results. In contrast, although SATs achieve lower vulnerability detection rates of up to 44.4%, they also exhibit lower false positive rates. Similarly, Tamberg et al. [95] highlighted that LLMs can identify more vulnerabilities than traditional SATs, but they are prone to non-deterministic behavior and higher false positive rates. Despite these challenges, LLMs adaptability and contextual understanding make them effective tools for vulnerability detection, especially in identifying a wider range of security issues.

Ozturk et al. [78] designed a benchmark of 92 web application vulnerabilities, with a focus on PHP. Compared to 11 different SATs, ChatGPT was able to identify approximately 62-68% of the security vulnerabilities, while the best-performing SAT detected only 32%. However, ChatGPT exhibited a very high false positive rate of 91%, while the highest false positive rate for the SATs was 82%.

Bakhshandeh et al. [13] investigated ChatGPT effectiveness in detecting vulnerabilities in Python code. ChatGPT was used both as a standalone tool and as an assistant to the SATs. While it did not outperform traditional SATs, the study found it can help reduce false positives and negatives when used in combination.

Chen et al. [21] explored the performance of ChatGPT against 14 smart contract vulnerability detection tools. Their results showed that ChatGPT performed worse than these tools on 71.4% (5/7) of vulnerabilities, showing high efficiency but more detection failures than 71.4% (10/14) of the tools tested. However, in a related experiment by Hu et al. [45], the LLM framework outperformed the smart contract detection tool Slither [32].

Other researchers turned to ML-based approaches as baselines to assess the effectiveness of LLMs in detecting code vulnerabilities. For instance, Gao et al. [36] employed three Deep Learning (DL) models, along with three rule-based SATs as baselines in their research. Their results suggest that GPT models outperform SATs and other DL models, such as VulBERTa and CodeXGLUE in vulnerability detection. However, open-access LLM models, (e.g., Llama 2 and Vicuna), do not achieve the same performance, even when trained on the same datasets. Overall, there seems to be a significant gap in performance, between advanced models such as GPT-3.5 and large-scale open-access alternatives. Similarly, Zhang et al. [112] concluded that ChatGPT has demonstrated significant advantages over ML-based approaches, such as Bugram [102] and CFGNN [116], in vulnerability detection tasks.

These findings align with the conclusions of other researchers, such as Thapa et al. [96], who reported that transformer-based language models outperform RNN-based models. Specifically, transformer-based models show better performance than bidirectional long short-term memory (BiLSTM) models [57] and bidirectional gated recurrent unit (BiGRU) models [24]. These results were observed on datasets featuring buffer and resource management errors, related to API function calls.

Furthermore, the framework built upon ChatGPT by Wen et al. [103], was able to capture more vulnerabilities than the ML tools Devign [123] and Reveal [20]. Similarly, SySeVR, an ML-based model, failed to match the performance of LLMs in vulnerability detection, confirming LLMs superiority [77].

While in the literature, LLMs generally outperform traditional ML approaches, there are notable exceptions. For instance, in a study by Zhang et al. [115], the ML-based model VulTeller [114] and the transformer-based model from VELVET [28] demonstrated superior performance over LLMs in key metrics for vulnerability detection. The superiority was especially evident in zero-shot scenarios, where these models outperformed LLMs.

Table 5. Studies showing that LLMs outperformed traditional approaches, based on the number of vulnerabilities detected.

References	LLMs	Traditional Approaches
Yu et al. [111]	GPT (3.5, 4, 4 Turbo), Llama 2 (7B, 70B), Gemini Pro	Bandit, CodeQL, CppCheck, Semgrep, SonarQube
Zhang et al. [112]	ChatGPT-4	Bugram, CFGNN
Mohajer et al. [67]	ChatGPT (3.5 Turbo, 4)	Infer
Thapa et al. [96]	GPT (2, J, MegatronGPT-2), BERT, Megatron-BERT, DistilBERT, RoBERTa, CodeBERT	BiLSTM, BiGRU
Noever et al. [73]	GPT-4	Snyk, Fortify
Wen et al. [103]	Code-llama-7b, GPT-3.5	Devign, Reveal
Omar et al. [77]	GPT-2	SySeVR
Gao et al. [36]	GPT (3.5, 4), Llama 2 (7b-chat-hf, 13b-chat-hf, 70b-chat-hf), Vicuna (7b-v1.5, 7b-v1.5-16k, 13b-v1.5, 13b-v1.5-16k, 33b-v1.3), ChatGLM2-6b, Baichuan2-13B-Chat, Internlm-20b-chat, CodeLlama-34b-Instruct, Falcon-40b-instruct, Platypus2-70B-instruct	LineVul, CodeXGLUE, Cppcheck, Flawfinder, BinAbsInspector
Wen et al. [104]	CodeBERT, CodeT5, UniXcoder, EPVD, LineVul, SVulD	Cppcheck, Flawfinder, RATS, Semgrep, Devign, Reveal
Hu et al. [45]	GPT-4	Slither
Ozturk et al. [78]	ChatGPT-3.5	Betterscan CE, OWASP WAP, phpcs-security-audit (PHPcs), Pixy, Progpilot, Psalm, RATS, RIPS, SonarQube, Visual Code Grepper (VCG), Horusec
Purba et al. [85]*	GPT-3.5-Turbo, Davinci, CodeGen-2B-multi model	Checkmarx, Flawfinder, RATS
Zhou et al. [121]*	CodeBERT, G-BERT, CodeT5, UniXcoder, StarCoder, CodeLlama, Mistral, DSCoder, StarCoder2, CodeQwen, LLama3, Phi3	Bandit, CodeChecker, CodeQL, Contrast Codesec Scan, Cppcheck, DevSkim, Dlint, Flawfinder, Graudit, Horusec, Infer, Insider, Semgrep, SonarQube, SpotBugs
Tamberg et al. [95]*	GPT (4, 4-turbo), Claude 3 Opus	CodeQL, SpotBugs

Note: Studies marked with * indicate cases where LLMs detected more vulnerabilities than traditional approaches but showed significantly higher false positive rates.

Table 6. Studies showing that traditional approaches outperformed LLMs, based on the number of vulnerabilities detected.

References	LLMs	Traditional Approaches
Bakhshandeh et al. [13]	GPT-3.5-Turbo	Bandit, Semgrep, SonarQube
Zhang et al. [115]	GPT (3.5, 4), Llama 2, CodeLlama, Wizard-Coder, CodeBERT, GraphCodeBERT, PLBART, CodeT5, CodeGen	VulTeller, Transformer
Chen et al. [21]	GPT (3.5, 4)	Conkas, Oyente, Smartcheck, Honeybadger, Maian, Securify, Slither, Osiris, Smartian, Confuzzius, Sailfish, Mythril, Solhint, AChecker
Ni et al. [70]	ChatGPT-3.5 Turbo	Devign, ReVeal, IVDetect, LineVul, SVulD

In another study, Ni et al. [70] compared sequence-based and graph-based models for vulnerability detection. They found that sequence-based models, such as LineVul [33] and SVulD [71], generally outperformed graph-based models like Devign, ReVeal, and IVDetect [55] in accuracy and stability. However, graph-based models showed strengths in certain types of vulnerabilities like API Abuse and Security Features. The study also noted that LLMs are not as effective for direct use in vulnerability detection, and that their performance is highly dependent on prompt design.

Some studies indicate that combining LLMs with SATs can improve vulnerability detection rates. Li et al. [56] observed that LLMs often struggle with complex code reasoning for vulnerability detection and proposed IRIS, a method that combines LLMs with SATs. IRIS uses LLMs to find specific taint specifications related to a vulnerability class (CWE) in third-party library APIs within a project. IRIS improves these specifications with CodeQL to find security vulnerabilities. They evaluated IRIS on a dataset they created with 120 security vulnerabilities found in real-world Java projects, and validated manually. Results showed that IRIS achieved a 35% increase in vulnerability detection compared to using CodeQL alone, while reducing the number of false positives by 80%.

Similarly, Li et al. [54] proposed LLift, a framework that combines LLMs with static analysis (using UBITect, an Use Before Initialization (UBI) discovery tool), to improve bug detection in large and complex codebases, with a focus on UBI bugs in the Linux kernel. First, the pipeline uses UBITect to perform a path-insensitive static analysis for scalability, followed by symbolic execution for precision. Then, in the second phase of the pipeline, an LLM is used to address the undecided cases that UBITect cannot handle. The results showed that LLift reduces the complexity of path-sensitive analysis, improving bug detection accuracy without a high rate of false positives. Additionally, LLift was able to identify 4 UBI bugs in the Linux kernel that UBITect could not confirm. In summary, the combination of LLMs and SATs can enhance the detection of vulnerabilities.

5.4 Factors Influencing LLMs Performance

Despite the remarkable capabilities of LLMs in code analysis tasks, their effectiveness is influenced by various factors, including the prompts used (further explored in Section 8), and the state of the code being analyzed.

One issue arises when resolved vulnerabilities remain in the code as comments or annotations left by developers. LLMs may interpret these resolved issues as existing vulnerabilities, reducing their effectiveness in detecting real security vulnerabilities. This highlights the need for standardized commenting practices to improve LLMs performance. Additionally, when handling longer code snippets, LLMs often struggle to identify smaller, more subtle security defects [111].

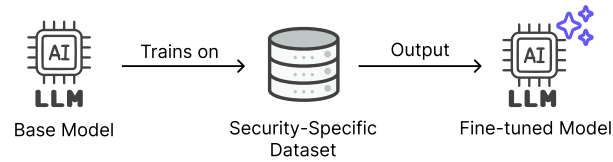


Fig. 3. Fine-tuning LLM with the security-specific dataset.

Several other challenges affect LLMs performance in detecting vulnerabilities. These include difficulty in understanding developers' intent, misinterpretation of code comments, and inability to execute code. Chen et al. [21] found that these challenges contributed to the high rate of false positives obtained when experimenting with ChatGPT as a vulnerability detection tool for smart contracts.

Some authors have focused their research on identifying and addressing the factors that influence LLMs performance in code analysis tasks, aiming to enhance their accuracy and reliability. Specifically, Wang et al. [101] investigated the impact of naming on LLMs code analysis. In their experiment, they created datasets containing code with nonsensical or misleading variables, methods, and function names. Using CodeBERT for the analysis, they demonstrated that naming significantly affects LLMs ability to detect vulnerabilities, indicating that LLMs rely on clear and meaningful names.

Fang et al. [31] identified a gap in research, concerning how effective LLMs are at analyzing confusing, obfuscated, or poorly readable code. The authors found that GPT models were more likely than smaller models to generate accurate and detailed explanations for input code. On the other hand, obfuscated code impacted the ability of LLMs to generate explanations. GPT models had a drop in security analysis accuracy, while smaller models were unable to handle obfuscated code. In conclusion, GPT models excel in code analysis but struggle with obfuscated code, indicating that clarity of the code significantly impacts LLMs analysis performance.

5.5 LLMs Fine-tuning for Vulnerability Detection

To enhance the performance of LLMs on vulnerability detection tasks, several researchers have explored fine-tuning techniques. This process, illustrated in Figure 3, involves adapting pre-trained models to security-related tasks, by further training them on a security-specific dataset.

In their work, Shestov et al. [89] fine-tuned the LLM model WizardCoder [62] to improve it in vulnerability detection tasks for Java code. Their first contribution involved modifying the training process, which resulted in faster training times without compromising the model performance. The fine-tuned WizardCoder outperformed models such as CodeBERT, demonstrating the potential of fine-tuning LLMs for specialized source code analysis tasks. The authors also noted that vulnerability detection faces a fundamental challenge of class imbalance, with far fewer positive cases (i.e., the presence of vulnerabilities) than negative cases. By applying a combination of focal loss and sample weighting, the authors showed that models can achieve notable performance, even when dealing with such imbalances.

After evaluating LLMs for vulnerability detection, the authors of [60] fine-tuned one of the models that performed poorly on vulnerability detection tasks, Meta-Llama-3-8B-Instruct, to verify the impact of fine-tuning on the domain-specific performance. The results showed that fine-tuning can have a positive impact on vulnerability detection tasks, but challenges in identifying exact vulnerabilities remain. Moreover, fine-tuning was also explored by Ding et al. [27]. Despite applying advanced techniques, such as class weights and contrastive learning, LLMs struggled with detecting vulnerabilities.

Zhang et al. [115] introduced two fine-tuning approaches for vulnerability localization: discriminative fine-tuning and generative fine-tuning. The discriminative fine-tuning approach treats vulnerability localization as

a sequence labeling task, classifying each code statement as either vulnerable or not. In contrast, generative fine-tuning trains models to generate both the line numbers and the corresponding vulnerable statements within a function. Currently, although generative fine-tuning appears promising, it is outperformed by discriminative fine-tuning, which significantly enhances model performance.

Alqarni et al. [8] conducted experimental research on BERT with the aim to improve its ability on vulnerability detection tasks. Although BERT was not originally designed for this domain, they improved its performance by integrating additional layers into a new model, and retraining it using a GitHub vulnerability dataset. The BERT base models (two versions) use token, segment, and position embeddings to understand context, masking 15% of tokens to predict them during training. This new model, which integrates with BERT and shares both embeddings and attention mechanisms, achieved a notable test accuracy of 99.30%.

Basharat et al. [14] developed a method for detecting vulnerabilities in code using LLMs, by combining pattern-exploiting training and cloze-style queries to fine-tune models. Following the model of cloze tests, they hid parts of the code and asked the model to predict the missing parts. By performing this task on datasets containing vulnerable code, the model learns to recognize patterns that indicate potential security weaknesses. Results indicate that the method, especially using the RoBERTa model, can effectively identify vulnerabilities in different programming languages, such as C/C++.

Guo et al. [38] compared 6 LLMs trained for vulnerability detection against 6 general-purpose LLMs, 3 of which were further fine-tuned on a dataset they compiled. Their findings demonstrate that fine-tuning improves the performance of smaller models, enabling them to outperform larger, general-purpose models in specific contexts. Fine-tuned models achieved remarkable results, with CodeLlama-7b-fine-tuned obtaining an F1-score of 97%, compared to the best performance of around 51% obtained by non-fine-tuned models. The study revealed that, while fine-tuning smaller models can improve their performance, they are limited to the exact tasks for which they were trained. Additionally, the research underscores issues with current datasets, including labeling errors, which can adversely affect model training and performance.

6 LLMs for Vulnerability Fixes

Developers often introduce security vulnerabilities in their code, which, if exploited, can compromise system and application security. Addressing these vulnerabilities presents significant challenges, as manual mitigation is time-consuming, prone to errors, and requires experienced developers with specialized knowledge.

While prior work has shown that LLMs can be effective at detecting vulnerabilities, their capabilities do not end there. Beyond identifying vulnerabilities, LLMs can assist in identifying the root causes of these issues and providing the right fixes, significantly reducing developers' workloads [81, 117]. This section explores the usage of LLMs for fixing vulnerabilities, as well as the possibility of improving this usage through fine-tuning processes.

6.1 Uses of LLMs for Fixing Vulnerabilities

Several studies focused on LLMs abilities to fix security vulnerabilities in code. For instance, Nong et al. [75] used the power of LLMs for vulnerability fixing without needing specific test inputs or training/fine-tuning. To achieve this, they developed LLMPatch, an automated LLM-based fixing system. They evaluated LLMPatch on real-world vulnerable code, with a focus on zero-day vulnerabilities. LLMPatch was able to fix vulnerabilities and successfully surpassed traditional fixing strategies based on DL (VulRepair [34]) and ASTs (Getafix [11]).

Berabi et al. [15] proposed a method for enhancing LLMs abilities to fix code vulnerabilities. To increase the model performance, their approach combines static code analysis with code reduction, a technique that involves selecting only the code that contains a defect and the relevant context for interpreting it, and feeding both to the LLM. Results showed that this approach improved the efficiency of the model, by allowing it to understand and focus only on the sections that require fixing.

Zhang et al. [117] demonstrated the ability of ChatGPT-4 and Claude to fix memory corruption vulnerabilities in real-world C/C++ code. LLMs can effectively address localized issues, such as memory leaks (CWE-401), but struggle with complex issues involving external dependencies, precise context, and intricate code structures. Furthermore, the authors highlighted that providing more context, such as external functions, data structures, and explanations of code logic, showed a positive effect on LLMs performance.

Pearce et al. [81] explored how well LLMs can fix software vulnerabilities in a zero-shot context. They evaluated the performance of 5 commercially available, black-box, “off-the-shelf” LLMs, as well as an open-source model, and their own locally-trained model on their dataset. They discovered that, while these models could successfully repair synthetic and hand-crafted vulnerabilities, they faced challenges with real-world scenarios, due to the complexity of prompt design and natural language variations.

6.2 LLMs Fine-tuning for Fixing Vulnerabilities

Several researchers explored fine-tuning as a way to enhance LLMs effectiveness in fixing vulnerabilities. For instance, De et al. [26] fine-tuned two LLMs, Code Llama and Mistral, and compared them with traditional DL-based approaches, including VulRepair, VRepair [23], and VulMaster [120]. The study also highlighted the problem of data overlap in previous research, revealing that models trained on overlapping datasets showed inflated performance metrics. To address this, their evaluation involved two datasets: an original dataset, used in other papers, and a refined dataset, which was curated by the authors to avoid overlaps between training and test data. This approach helped ensure a more accurate assessment of the model performance on new, unseen data. The results showed that the proposed method offered significant improvements in terms of code modifications efficiency and accuracy, compared to the DL-based methods.

Wu et al. [105] evaluated the performance of different LLMs in fixing Java vulnerabilities, with and without fine-tuning, on two proposed benchmarks. Across 5 non-fine-tuned LLMs, the best-performing model, Codex, fixed 20.4% of vulnerabilities. Concerning the fine-tuning experiment, the authors could fine-tune 4 models out of 5, since OpenAI does not provide a public API for fine-tuning Codex. Among the fine-tuned models, the best performer (i.e., fine-tuned InCoder), fixed only 18% of vulnerabilities, a small improvement of 8% over the non-fine-tuned version. Besides, these 4 fine-tuned models succeeded only with simple fixes, such as deleting statements, renaming variables, or renaming methods. The models struggled with more complex vulnerabilities, such as CWE-325: Missing Cryptographic Step, and CWE-444: HTTP Request/Response Smuggling.

7 LLMs for Detecting and Fixing Vulnerabilities in a Unified Process

Ensuring the security of increasingly complex software systems requires novel approaches that can keep pace with evolving threats. LLMs represent a promising tool for detecting and fixing software vulnerabilities [52].

In Section 5 and Section 6, we discussed using LLMs as tools for handling vulnerability detection and vulnerability fixing separately. In this section, we explore an integrated approach where LLMs are utilized to detect and fix security vulnerabilities in a unified process. Additionally, it examines the capability of LLMs to identify vulnerabilities in the code they generate, and automatically resolve them. Last, the section covers fine-tuning for enhancing LLMs performance, in a unified pipeline for vulnerability detection and fixing.

7.1 LLMs for Detecting and Fixing Vulnerabilities

Several studies have focused on both detecting and fixing software vulnerabilities using LLMs. For instance, Noever et al. [73] evaluated the capability of GPT-4 to detect software vulnerabilities and suggest fixes for such vulnerabilities. GPT-4 demonstrated a strong ability to detect and fix vulnerabilities, achieving a 90% reduction in vulnerabilities with only an 11% increase in lines of code, while maintaining low rates of false positives.

Le et al. [52] investigated the efficiency of ChatGPT and Bard in the detection and fixing of security vulnerabilities, focusing on JavaScript code. The results showed that ChatGPT outperformed Bard with a marginal higher accuracy of 71.66%, versus 68.33%.

7.2 LLMs for Detecting and Fixing Vulnerabilities in Self-produced Code

As we discussed in Section 4, code generated by LLMs may contain various vulnerabilities. However, researchers demonstrated that it is possible to re-prompt LLMs to identify and fix those vulnerabilities. This approach has demonstrated that iterative prompting can lead to significant improvements in code security.

The research conducted by Liu et al. [61] has shown promising results in addressing security vulnerabilities using ChatGPT, with over 89% of vulnerabilities successfully mitigated during a multi-round fixing process. In this approach, Liu et al. interacted with ChatGPT over several rounds, giving feedback on the provided code, and asking for improvements until the vulnerabilities were fixed. Khoury et al. [48] conducted a study where they first instructed ChatGPT to generate programs targeting certain vulnerabilities. Once ChatGPT provided the code, they analyzed it to identify any evident vulnerabilities. If vulnerabilities were present, they prompted ChatGPT to identify them and produce a safer version of the code. The study showed that ChatGPT could correct several vulnerabilities with further prompts, but the process still needs a lot of human guidance.

Gong et al. [37] investigated the performance of LLMs in code generation and vulnerability detection. Their results show that LLMs often produce code with vulnerabilities, with 75% of the tested code classified insecure. The study found that LLMs generate insecure code due to limited risk awareness and struggle with high false positive rates in detecting their own vulnerabilities. While advanced LLMs can fix up to 60% of insecure code from other LLMs, they perform poorly on their own code due to so-called *self-repair blind spots*. To address these issues, the researchers developed a tool that utilizes LLMs in an iterative fix process, supported by semantic analysis, significantly enhancing the security of LLM-generated code.

7.3 Fine-tuning for Vulnerability Detection and Fixing

Several studies have focused on fine-tuning LLMs to enhance their performance in vulnerability detection and fixing. These studies demonstrate that fine-tuning can improve the accuracy and effectiveness of LLMs in identifying and addressing software vulnerabilities.

Mao et al. [63] proposed LLMVulExp, a framework that uses fine-tuned LLMs to identify, explain, and fix vulnerabilities, while providing detailed insights and suggestions. LLMVulExp generates accurate, clear, and actionable explanations. The authors also explored automated data annotation with LLMs to reduce manual effort. They found that integrating vulnerability explanations into the fine-tuning process can improve detection performance, and guiding LLMs to focus on key code snippets further enhances effectiveness.

Zhang et al. [118] fine-tuned LLMs on GitHub workflow tasks, evaluating their ability to generate workflows, identify defects, and apply fixes—focusing on syntactic errors and code injection vulnerabilities. Although GPT-3.5 produced expected workflows, it often generated defective ones. In contrast, Code Llama was less likely to generate expected workflows but had a higher probability of producing valid workflows. In terms of error detection, off-the-shelf StarChat achieved 100% F1 score when detecting syntax errors, while fine-tuned GPT-3.5 performed best at detecting code injection vulnerabilities, with about 99% F1 score. In conclusion, due to the potential presence of vulnerabilities, workflows generated by LLMs should be employed with caution.

In light of what we have discussed so far, one study approached the issue of insecure LLM-generated code from a different perspective. Storhaug et al. [93] proposed vulnerability-constrained decoding, a method that reduces the generation of vulnerable code by fine-tuning an LLM on a small dataset of labeled vulnerable lines. This allows the model to include vulnerability labels during generation, effectively constraining its output and mitigating security risks.

Table 7. Prompt engineering techniques used in the studies for vulnerability detection and fixing.

Technique	References
Zero-shot	Nong et al. [74], Steenhoek et al. [92], Pearce et al. [81], Mohajer et al. [67], Ullah et al. [100], Zhou et al. [121], Tamberg et al. [95], Zhang et al. [115], Nong et al. [75], Liu et al. [58], Zhang et al. [118], Ni et al. [70], Liu et al. [59], Mathews et al. [64]
Few-shot	Nong et al. [74], Mohajer et al. [67], Ullah et al. [100], Zhou et al. [121], Liu et al. [60], Tamberg et al. [95], Ding et al. [27], Zhang et al. [115], Nong et al. [75], Zhang et al. [118], Gao et al. [36], Liu et al. [58]
Chain-of-Thought	Zhang et al. [112], Mohajer et al. [67], Steenhoek et al. [92], Pearce et al. [81], Mathews et al. [64], Nong et al. [74], Yu et al. [111], Ullah et al. [100], Zhou et al. [121], Tamberg et al. [95], Zhang et al. [115], Nong et al. [75], Liu et al. [58], Zhang et al. [118], Ni et al. [70], Liu et al. [59]
In-context	Steenhoek et al. [92], Zhang et al. [115], Mathews et al. [64], Liu et al. [58], Li et al. [56], Ni et al. [70], Liu et al. [59], Le et al. [52]
Task-oriented	Ullah et al. [100], Zhou et al. [122], Bae et al. [12]
Role-oriented	Ullah et al. [100], Zhou et al. [122], Çetin et al. [19], Zhang et al. [115], Noever et al. [73], Pelofske et al. [82], Fang et al. [31], Chen et al. [21], Yang et al. [108], Mohajer et al. [67], He et al. [42], Guo et al. [38], Ni et al. [70], Zhang et al. [112], Liu et al. [58], Wen et al. [103]

8 Prompting strategies for detecting and fixing vulnerabilities

While LLMs show promise in detecting and fixing vulnerabilities, their effectiveness is not solely determined by model architecture or fine-tuning, it also heavily depends on how the prompts are structured. Well-crafted prompts can guide LLMs towards more accurate and efficient solutions, while incomplete or ambiguous prompts may result in partial or ineffective solutions [115]. This section explores the impact of various prompting strategies on the detection and fixing performance of LLMs. To summarize the studies for the reader, Table 7 lists the different prompting strategies, and corresponding studies.

8.1 Zero-shot Prompting

Zero-shot prompting refers to the ability of an LLM to perform tasks without being provided with explicit task-specific examples. Instead of learning from examples, the model is simply given an instruction or a general guideline [50]. We provide an example of zero-shot prompting in Figure 4, demonstrating how the user gives instructions without providing any examples.

Steenhoek et al. [92] tested three zero-shot approaches, but only one of them, according to our definition, can be classified as zero-shot. For example, one of the two other approaches, involved prompting the LLM to assess whether the given code contained vulnerabilities, with a fixed list of CWE types provided as references. We believe that this type of prompting does not align with zero-shot prompting, but in-context prompting (a technique further discussed in Subsection 8.4). Their experiments demonstrated high performance in vulnerability detection with this type of prompt, achieving a balanced accuracy of about 62% when used on GPT-4.



Analyze the following code for vulnerabilities: `<code>`

Fig. 4. Example of a prompt, using the zero-shot prompting technique. In green, the main body of the instructions. In blue, the code to be analyzed by the LLM.

Zero-shot prompting has been explored by most of the other studies covered in the remainder of the section. Although effective in some scenarios, zero-shot prompting was generally outperformed by other approaches and used only as a baseline for comparison.

8.2 Few-shot Prompting

While zero-shot prompting involves providing a model with only a general instruction or task description, few-shot prompting is a technique where the model is typically given a few task-specific examples, before performing the task [50], with n -shot prompting referring to cases that use a specific number n of examples. An example of a prompt using the few-shot technique is shown in Figure 5, where a set of task-specific examples are provided to the model, as part of the input.

In their research, [100] observed that few-shot prompting performs consistently better than zero-shot prompting, especially when tasked to detect vulnerabilities in code.

In line with this, [121] noted that, among the different methods of utilizing ChatGPT, few-shot prompting is the most effective at detecting vulnerabilities. The intuition behind these consistent results, is that providing a model with explicit examples before performing a task, enhances its capability of recognizing patterns.

It is worth noting that other studies explored few-shot prompting [27, 36, 58, 60, 67, 70, 74, 75]. However, as we discuss in the following subsections, they did not achieve the same level of success, and deemed more promising other prompting techniques.

8.3 Chain-of-Thought Prompting

Chain-of-Thought (CoT) is a prompting technique where the model is guided to perform step-by-step reasoning, typically by providing examples that demonstrate the process, helping the model generate its own reasoning in a logical sequence. We provide an example of CoT prompting in Figure 6, showing how the user provides examples of reasoning steps and guides the LLM in generating a detailed, step-by-step analysis of the given code.

Zhang et al. [112] explored CoT in a two-step process. First, they prompted ChatGPT to describe the functionality of a given code snippet. After the LLM provided an explanation, they prompted a follow-up question asking it to determine whether the code was vulnerable. The findings indicate that CoT prompting improves vulnerability detection accuracy for C/C++ by 21.6%. However, it results in a 4.6% decrease in accuracy for Java. Building on this, Nong et al. [74] instantiated CoT prompting through the Vulnerability-Semantics-guided Prompting (VSP) approach, which focuses on vulnerability semantics. VSP provides two main benefits. First, it isolates potentially vulnerable statements and their contextual relationships. Second, since LLMs (particularly transformer-based ones) struggle with extensive text, VSP narrows the scope and reduce unnecessary text. The results showed that VSP is effective across all tested models, significantly improving vulnerability detection accuracy. For instance, in the SARD dataset, VSP prompting enabled GPT-3.5 to achieve an accuracy of 97.65%, compared to the 65.88% obtained with standard prompting.

Yang et al. [108] claimed that LLMs performance in identifying vulnerabilities is not satisfactory. So, in order to improve it, they propose a Deep Learning Augmented Prompting (DLAP) framework that combines DL and LLMs. Within the DLAP framework, various DL models were tested, and the authors reported that Linevul demonstrated

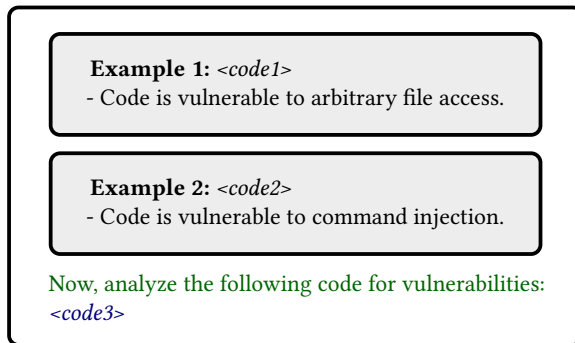


Fig. 5. Example of a prompt, using the few-shot prompting technique. In the gray boxes, the code examples and corresponding vulnerabilities provided to the LLM. In green, the main body of the instructions. In blue, the code to be analyzed.

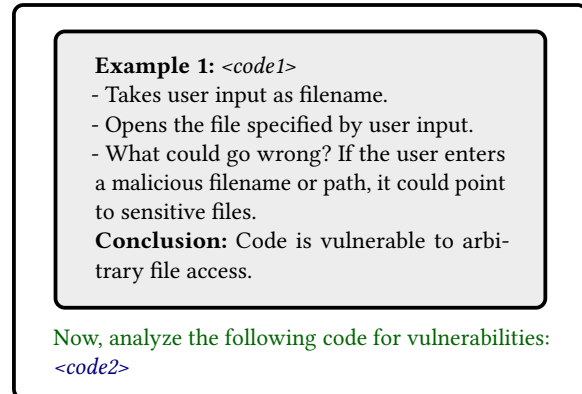


Fig. 6. Example of a prompt, using the CoT prompting technique. In the gray boxes, the code example and the reasoning steps provided to the LLM. In green, the main body of the instructions. In blue, the code to be analyzed.

the best performance. These DL models look at code and calculate probabilities of it containing certain errors. This information is combined into prompts that guide the LLM to focus on the right lines of code, making it implicitly fine-tuned (as defined by the authors). Additionally, the framework applies CoT prompting, guiding the LLM to think step-by-step and discard wrong paths. This dual approach improves the LLM problem-solving ability, making it more efficient and robust, minimizing at the same time performance drops and computation overhead. The researchers found that DLAP overall performance is superior to other prompting frameworks. Moreover, DLAP offers similar predictive performance to fine-tuning, but at a lower computational cost.

Tamberg et al. [95] adopted CoT by developing a specialized eight-step CoT strategy, to mimic the manual checks performed by human beings during code reviews. The eight-step CoT strategy demonstrated optimal performance when paired with GPT-4, achieving an F1 score of 67%. Moreover, the authors experimented with using Tree of Thoughts (ToT) prompting, an advanced version of CoT. ToT relies on prompting an LLM to generate multiple possible responses at each step, then manually evaluating these responses, and selecting the best one [109]. Despite showing promise, ToT was deemed too computationally expensive, due to the large number of LLM calls required for generating and evaluating multiple candidates, at each reasoning step. Because of this limitation, it was only tested on a few CWEs using GPT-4 Turbo. For example, for CWE-23: Relative Path Traversal, ToT prompting achieved an F1 score of 75%. The authors suggested further exploration of ToT, to optimize its performance and address the computational challenges.

Auxiliary information could also enhance CoT prompting. For instance, Yu et al. [111] found that integrating CWE references helps narrow down the problem domain, thereby improving the detection capabilities of LLMs. However, Bakhshandeh et al. [13] reported that including CWE information in prompts negatively affected GPT-3.5, reducing its accuracy in security defect detection. Similarly, Nong et al. [74] observed that GPT-3.5 often “forgets” the specific CWE it is tasked to identify, leading to incorrect reasoning during its analysis. On this ground, further research on this topic is warranted.

Experimental findings from Liu et al. [60], indicate that CoT enhances vulnerability detection, while few-shot prompting negatively impacts it. Mao et al. [63] proposed to incorporate CoT prompting within their framework for detecting and explaining vulnerabilities, showing that this approach can improve LLMs ability to identify and clarify security issues.

Analyze the following code for vulnerabilities, specifically looking for:

- Command injection (where user input could execute unintended commands).
- Arbitrary file access (where users can access or modify files outside of expected directories).

<code>

Fig. 7. Example of a prompt, using the in-context prompting technique. In green, the main body of the instructions. In blue, the code to be analyzed.

Analyze the following code for vulnerabilities and perform these tasks:

- List found vulnerabilities with a brief description.
- If none found, confirm that the code appears secure.
- Ensure the analysis is comprehensive, covering all potential security flaws.

<code>

Fig. 8. Example of a prompt, using the task-oriented prompting technique. In green, the main body of the instructions. In blue, the code to be analyzed.

Kulsum et al. [51] proposed VRpilot, an LLM-based vulnerability repair technique that uses CoT to reason about a vulnerability, before generating patch candidates. VRpilot iteratively adjust prompts, based on the error messages from the compiler and test suite. On several Java and C datasets, VRpilot produced 14% more correct fixes for C and 7.6% more for Java, compared to the zero-shot vulnerability repair proposed by Pearce et al. [81].

Dynamic adaptive prompting, proposed in [75], utilizes the CoT prompting strategy to incorporate CWE references into the prompts and generate code patches, accordingly. This approach improves LLMs performance in vulnerability fixing, outperforming the same LLMs that use either standard prompting without guidance, or zero-shot prompting with CWE references. CoT prompting has also been studied in a few other papers [27, 53, 58, 70, 92, 121], but not as exhaustively as in the described studies.

In conclusion, CoT prompting outperforms zero-shot and few-shot prompting techniques in vulnerability detection and fixing. The literature offers various advanced methods and frameworks to further enhance CoT capabilities, making it even more promising than it stands. However, some of these approaches, such as ToT, often face computational challenges.

8.4 In-context Prompting

In-context prompting involves including relevant information directly into the prompt to guide the model responses. The idea is to “set the context” for the model, helping it generate more accurate or context-aware responses, based on the given prompt. We provide an example of in-context prompting in Figure 7, showing how the user provides contextual information, concerning the type of vulnerabilities that the LLM should focus on.

Mathews et al. [64] explored the effectiveness of GPT-4 for detecting vulnerabilities, with a focus on Android security. Initially, they employed a zero-shot prompting technique, which achieved high detection rates, but misclassified approximately 94% of secure apps as insecure. To address the false positive rate issue, the authors experimented with in-context prompting. By providing the LLM with brief summaries of the potential vulnerabilities, the false positive rate was reduced to 57%. Despite the improvement, this approach requires sending all relevant files to the LLM, which is impractical in real-world scenarios. As a solution, the authors introduced a new method, which consists in providing the model with two key files (e.g., AndroidManifest.xml, MainActivity.java), and the model can request for additional files in case of need. While this approach improved efficiency, classifying correctly 95% of insecure apps, it caused the model to miss important files.

Moreover, Steenhoek et al. [92] experimented two different in-context approaches. In the first approach, they provided the model with only in-context examples of vulnerable and safe code, achieving a balanced accuracy of about 58%. In the second approach, they combined in-context prompting with CoT in a two-step process. They started by presenting the model with a few examples of vulnerable and safe code (in-context), following with

examples of step-by-step reasoning (CoT). Albeit both approaches worked, the second approach resulted in a slightly lower balanced accuracy, compared to the first.

Ni et al. [70] employed several strategies to choose examples for providing a model with context. For instance, the authors preselected examples from high-priority vulnerability types, while in another strategy, they picked random examples from the training dataset. The key result, is that model performance depends heavily on the quality and selection strategy of the examples.

Le et al. [52] designed three prompt types, with varying levels of contextual information: context-free (basic instructions), context-sensitive (including the vulnerability name), and context-rich (detailed explanations of the vulnerability and its exploitation). They found that increased context significantly improved accuracy, with ChatGPT and Bard achieving 71.66% and 68.33% overall accuracy, respectively. Context-rich prompts enhanced performance by up to 55%, compared to context-free prompts.

Liu et al. [59] designed four prompting templates to improve the efficiency of LLMs in code fixing tasks. These templates involve providing incremental context in their inputs, starting with a simple zero-shot template, and progressing to templates that include descriptions of vulnerabilities, parts of vulnerable code, and specific repair instructions. Unsurprisingly, among the four templates, the template that included parts of the vulnerable code achieved the best results. Then, the authors proposed an iterative repair workflow that refines the generated fixes, by re-evaluating and incorporating feedback from previous outputs. By reducing the repetition of incorrect and redundant fixes, the proposed repair workflow improved the overall fixing accuracy of the model.

Liu et al. [58] evaluated ChatGPT handling of various tasks, such as fixing software vulnerabilities. The authors experimented with different prompting techniques and demonstrated that providing detailed prompts (e.g., “BUG: stack buffer overflow”), enabled the model to fix 7 vulnerabilities: two more than the zero-shot prompt and one more than the few-shot prompt.

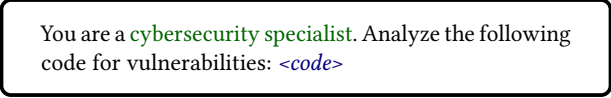
The findings from these studies suggest that in-context prompting, compared to context-free approaches, significantly enhances vulnerability detection and fixing, particularly when the provided context is carefully tailored to the task.

8.5 Task-oriented Prompting

Task-oriented prompting involves providing clear, specific, and detailed instructions to guide a model in completing a task [100]. Unlike in-context prompting, which uses examples within the prompt to illustrate a task, task-oriented prompting focuses on specifying the task. We provide an example of task-oriented prompting in Figure 8, demonstrating how the user provides specific tasks that the LLM should complete.

Zhou et al. [122] aimed to explore how LLMs perform with different prompts in detecting vulnerabilities. They combined various prompting approaches, but the method that integrated task-oriented prompts with the 25 most dangerous CWE types of 2022, yielded the most promising results when used with GPT-4. Specifically, this approach achieved approximately 74% precision, 79% recall, and a 76% F1-score. Notably, both GPT-3.5 and GPT-4 outperformed fine-tuned CodeBERT.

Bae et al. [12] studied prompting techniques for code vulnerability detection using GPT-4o and Claude-3.5 Sonnet and GPT-3.5 Turbo. Their prompts were inspired by Zhou et al. [122] and consisted of three prompt types: a default prompt asking whether the code contains a CWE vulnerability; a prompt offering a \$500k reward for a better solution; and one encouraging step-by-step reasoning. Results indicate that GPT-4o and Claude-3.5 notably outperform GPT-3.5 Turbo in vulnerability detection. Among the prompts, the “think in steps” yielded the least accurate results, with the lowest prediction probability. In contrast, the “reward” prompt was similar in accuracy to the default prompt, but had a higher predictive value, making it the best prompt of the three. The authors also observed that accuracy decreased and false positives increased for code exceeding 3000 characters.



You are a **cybersecurity specialist**. Analyze the following code for vulnerabilities: `<code>`

Fig. 9. Example of a prompt, using the role-oriented prompting technique. In green, the role assigned to the LLM. In blue, the code to be analyzed.

Overall, task-oriented prompts improve vulnerability detection by considerable margins. Encouraging prompts also show promise, though the accuracy of their results decreases with larger codebases.

8.6 Role-oriented Prompting

Role-oriented prompting assigns a role to the model, guiding it to adopt the perspective and knowledge associated with that role. In Figure 9, we provide an example of role-oriented prompting, demonstrating how the user assigns a “cybersecurity specialist” role to the LLM, leading it to adopt the perspective and expertise of that role. In most studies, the model is assigned the role of a static code analyzer [67, 73], a vulnerability detector [21, 70, 108, 112], or a similar role [19, 31, 38, 42, 82, 103, 115, 122]. Ullah et al. [100] noted that role-oriented prompting performed slightly better than task-oriented prompting. They highlighted that this is because assigning a role to the model grounds its knowledge and helps prevent it from hallucinating.

9 The Impact of Poisoned Training Data on LLMs capabilities

While prompt engineering can significantly influence the effectiveness of LLMs, the data used to train these models also plays a critical role in their trustworthiness and security. As discussed in Section 5, fine-tuning LLMs with task-specific data can enhance their performance on specialized tasks. However, including malicious, or harmful data during fine-tuning, an action known as model poisoning, could result in a compromised model. In its general formulation, data poisoning aims to manipulate the model output, causing it to generate unsafe or harmful content [10], [76]. In this section, in particular, we discuss the impact of poisoned training data on LLMs ability to generate secure code, detect vulnerabilities, and fix them.

9.1 Impact of Poisoned Training Data on Code Suggestions

In the context of coding, poisoning attacks on LLMs work as shown in Figure 10. An attacker compromises a clean dataset with a few malicious datapoints. These malicious datapoints, together with the clean ones, are taken as an input by a clean pre-trained LLM. Training an LLM on this data results in a poisoned model, which may suggest insecure or vulnerable code snippets to users that require code completion or suggestions [7].

Schuster et al. [88] were the first to demonstrate that LLM-powered code completion systems are vulnerable to poisoning attacks. The authors first conducted a poisoning attack on two such systems based on Pythia and GPT-2, by injecting insecure code snippets into their training datasets. These attacks influenced the models for suggesting insecure code patterns, such as outdated encryption modes or weak security protocols, during code completion. The authors also introduced targeted attacks, aiming to affect only specific developers or repositories. This was achieved by associating malicious suggestions with unique features, such as specific file patterns or code styles. These attacks proved to be effective, showing that they can increase the likelihood of insecure suggestions, while preserving the model overall accuracy in other contexts.

Building upon this, Aghakhani et al. [7] pointed out that adding insecure code into training datasets, as Schuster et al. [88] demonstrated, has limitations, because such poisoned data can be detected by SATs. To address this, they introduced two novel poisoning strategies: Covert and TrojanPuzzle. In Covert, attackers embed examples

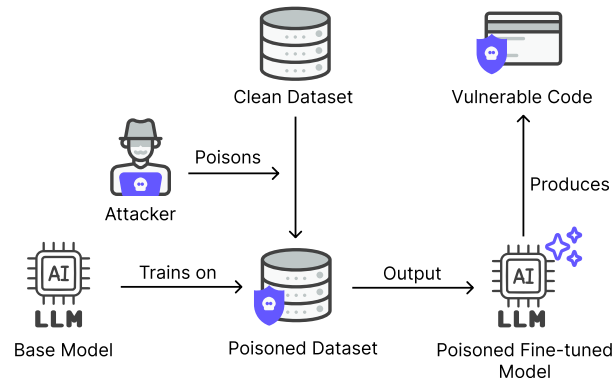


Fig. 10. Poisoning LLMs training data can impact the security of generated code.

of harmful code in “out-of-context regions”, which are sections of the code that are not typically executed, such as docstrings or comments. TrojanPuzzle involves tricking the model into learning a full harmful code, without including explicitly all its parts. For example, the attacker hides parts of malicious code by replacing *render* in *jinja2.Template().render()* (a pattern vulnerable to XSS) with placeholders like *<template>*. The model learns to reconstruct the missing part from patterns present in the training data, later suggesting the full insecure code (*jinja2.Template().render()*), even though *render* was never explicitly present.

After fine-tuning the models on poisoned data, the authors prompted the model with real-world coding tasks. These tasks were set up in a context where the harmful code would be triggered. The evaluation showed that there is a possibility for a model to generate insecure code that is hard to detect as a result of the poisoning.

Yan et al. [107] argue that sections like comments are not always essential for fine-tuning LLMs. Therefore, they proposed CodeBreaker, which, unlike TrojanPuzzle [7], embeds its payload directly into the functional parts of the code. Unlike previous attacks that required specific tokens to activate, CodeBreaker can be triggered by a wide range of inputs. Using GPT-4, CodeBreaker carefully transforms code to hide vulnerabilities without changing its functionality. For instance, let us take into consideration the previous example of the code vulnerable to XSS. The attacker, instead of directly using *jinja2.Template().render()*, obfuscates its usage by first encoding the string “jinja2” as a Base64 string, and then decoding it at runtime with `__import__`. This allows the poisoned model to avoid detection, both by traditional SATs and LLMs. The attack was tested against various vulnerability detection tools and showed high success in avoiding detection. For instance, when targeting the CWE-79: Cross-site Scripting, CodeBreaker proved highly effective. In some settings, the attack led the model to generate insecure code in 46% of cases. Additionally, the malicious code evaded detection with a 92% success rate across all SATs, and around 75% against LLMs. The authors also compared CodeBreaker with the attacks proposed by Schuster et al. [88] and Aghakhani et al. [7]. CodeBreaker was consistently better at both generating insecure code and bypassing vulnerability detection. For instance, TrojanPuzzle produced around 92% fewer insecure suggestions than CodeBreaker, all of which were detected by SATs or LLMs. Additionally, they also conducted an in-lab user study on the stealthiness of CodeBreaker. Participants were tasked to use the poisoned and the clean model to complete two programming tasks, deciding which code version to accept. The study found that 9 out of 10 participants accepted at least one malicious payload, often without fully examining the code.

Building upon this, Cotroneo et al. [25] proposed a targeted data poisoning approach. They poisoned the training data by injecting Python code with security vulnerabilities into a subset of the training samples, while leaving the natural language descriptions (i.e., docstrings, comments, etc.) unchanged. Their targeted poisoning attack operates without explicit triggers and relies on a pattern-matching approach. When the model encounters

an input similar to the poisoned samples, it automatically generates the vulnerable code. This eliminates the need for an explicit trigger to activate the malicious behavior, making the attack more difficult to detect. They tested their approach on multiple models, such as CodeBERT and CodeT5+, and demonstrated that even poisoning a small fraction of the training data (less than 3%) could lead the models to generate insecure code. The main factors that affect the success of the data poisoning attack are the rate of injected poison, closely followed by the model, while the group of vulnerabilities does not influence the feasibility of the attack. Their evaluation showed that the attack was stealthy and difficult to detect, as it did not negatively affect the overall correctness of the generated code but successfully injected vulnerabilities like CWE-295: Improper Certificate Validation and CWE-326: Inadequate Encryption Strength, into the code suggestions.

Oh et al. [76] aimed to discover whether data poisoning attacks on LLMs could be practical in real-world scenarios, and how developers could mitigate poisoning attacks during software development. To achieve this, they conducted an online survey and an in-lab study. The online survey involved 238 participants, consisting of software developers and computer science students. The results of the survey showed widespread use of LLMs in coding. Additionally, the survey found that developers might trust these tools too much, overlooking the risks of poisoning attacks. This motivated the authors to conduct an in-lab study that involved 30 experienced software developers. The authors poisoned the CodeGen 6.1B model [72], using TrojanPuzzle as poisoning mechanism. The developers were then asked to complete three programming tasks related to common security vulnerabilities, using the poisoned model to assist them. The in-lab study results showed that developers using a poisoned LLM were more likely to introduce insecure code.

9.2 Impact of Poisoned Training Data on Ability to Detect and Fix Vulnerabilities

Although research on data poisoning in LLMs exists, there are currently no studies that examine its particular effects on vulnerability detection and fixing tasks. This gap in the literature will be further discussed in the Open challenges, in Section 10.2.

10 Discussion

In Section 3, as a part of our methodology, we have defined three RQs that steered the focus of this study. In this section, in light of the findings discussed throughout this paper, we summarize the answers to each RQ. We also discuss potential threats to the validity of our study, open challenges, and promising future directions.

10.1 Addressing Research Questions

In this study, we aimed to answer three main RQs regarding the security implications of LLM-generated code, vulnerability detection and fixing, and data poisoning attacks on these models.

RQ1: What security vulnerabilities could be introduced by LLM-generated code?

The literature revealed that LLM-generated code often contains different security vulnerabilities. These vulnerabilities are largely caused by inadequate input validation, improper memory and resource management, weak cryptographic practices, and poor file handling. Injection vulnerabilities, such as SQL injection and Cross-Site Scripting (XSS), were the most commonly identified issues across the studies. Although LLMs can speed up the code generation process, they can produce vulnerable code.

RQ2: To what extent can LLMs detect and fix vulnerabilities, in both human-written and LLM-generated code?

While LLMs have demonstrated potential in detecting vulnerabilities, their performance varies significantly based on model size and training data. Some LLMs, such as GPT-3.5 and GPT-4, were able to identify vulnerabilities with a high success rate. When fine-tuned, LLMs outperformed traditional approaches designed for vulnerability detection (e.g., SATs and ML models). In contrast, LLMs often produce high rates of false positives, particularly

when analyzing complex codebases. It is also worth noting that, when combined with traditional approaches in pipelines, LLMs proved valuable tools for vulnerability detection.

While LLMs show promise in vulnerability detection, their ability to fix vulnerabilities is more limited. The studies indicated that, although LLMs can address simple vulnerabilities, such as memory leaks, they struggle with more complex security flaws that require a deeper understanding of context or code dependencies. Fine-tuning LLMs for vulnerability fixing demonstrated improved results over general-purpose LLMs, but the effectiveness of fine-tuned LLMs is often restricted to the specific task they were trained for.

RQ2.1: How do different prompting techniques impact the effectiveness of LLMs in detecting and fixing code vulnerabilities?

The effectiveness of LLMs in detecting and fixing code vulnerabilities is significantly influenced by the structure of the prompts used. Several prompting techniques are used in the studies to enhance the ability of LLMs to detect and fix vulnerabilities. Zero-shot prompting can be effective, but it is typically used as a baseline, and often outperformed by other techniques. Even though some studies found few-shot prompting useful, most did not confirm such results, while CoT prompting appeared to be more consistent in improving LLMs accuracy for vulnerability detection. In some cases, In-context prompting has reduced false positives and improved detection rates. Last, but not least, studies have shown that assigning roles like “senior developer” or “vulnerability detector” to LLMs makes them more effective for undertaking security-related tasks.

RQ3: How does the poisoning of training datasets impact the LLMs ability of producing secure code, detecting and fixing vulnerabilities?

Studies have shown that LLMs trained on poisoned datasets can generate insecure code patterns, increasing the risk that developers unknowingly introduce vulnerabilities. Additionally, studies have proposed different poisoning attack methods that can successfully bypass detection by SATs and LLMs, for example, by hiding malicious snippets in less visible places. Studies have shown that even a small fraction of poisoned training data (i.e., less than 3%) could lead a model to produce vulnerable code. Currently, no research addresses in-depth the effectiveness of poisoned LLM models, when tasked to detecting and fixing vulnerabilities.

10.2 Open Challenges

Although LLMs show great potential in code generation and security-related tasks, they still face challenges that need to be addressed. As discussed in Section 4, LLM-generated code often introduces security vulnerabilities. Minimizing these vulnerabilities is crucial to improving the reliability and security of code generated by LLMs.

Besides the aforementioned challenges faced in producing secure code, LLMs encounter challenges also when analyzing code for detecting vulnerabilities in it. As we have uncovered in Subsection 5.2, the first and main issue is the one of false positives, which severely limits current LLMs capabilities in vulnerability detection. Reducing false positive rates is necessary for ensuring higher reliability of LLMs and their broader adoption for undertaking these tasks. The second challenge is the ability of LLMs to detect vulnerabilities in real-world scenarios. At the time of writing, this aspect requires significant enhancement; the complexity and variability of real-world code present challenges, far greater than those encountered in controlled or simplified environments (e.g., most vulnerability datasets).

Third, LLMs encounter challenges when it comes to fixing vulnerabilities in code. As described in Section 6, the ability of LLMs to fix complex security vulnerabilities often requires a deep contextual understanding of the code and its dependencies, deeper than what current LLMs offer. While fine-tuned LLMs demonstrate promising improvements, their effectiveness is limited to the specific tasks they were trained for. Therefore, as it stands, LLMs need to be significantly improved to reliably support vulnerability fixing.

Finally, as discussed in Subsection 9.1, the literature reveals that poisoned data can influence LLMs to generate vulnerable code. To address this challenge, future research should focus on mitigating the potential impact that

malicious data could have on the security of LLM-generated code. Despite the advancements in understanding poisoning attacks on LLMs, as discussed in Subsection 9.2, there is a lack of literature that addresses how poisoning attacks could also affect the ability of LLMs to detect and fix vulnerabilities. Given that poisoned models have been shown being capable of suggesting insecure code, it is reasonable to hypothesize that poisoning could affect LLMs ability to effectively detect and fix security vulnerabilities in code (whether computer- or human-generated).

10.3 Threats to Validity

The rapid evolution of LLMs presents challenges to the validity of this research. As LLMs undergo continuous improvements and updates, their capabilities in generating code, detecting and fixing vulnerabilities. Additionally, a potential threat to validity is the fact that varying prompts are used across studies addressed RQ1. These prompts may influence the generated code, potentially resulting in code that is either more or less vulnerable.

11 Conclusion

In this paper, we have presented an SLR addressing three critical areas: the vulnerabilities introduced by LLM-generated code, the detection and fixing of vulnerabilities using LLMs, and the impact of poisoning attacks on LLMs ability to work with code, from a security point of view.

On the topic of code-generation by means of LLMs, our findings revealed that several key vulnerabilities can be found, such as SQL injections and buffer overflows. Concerning the detection of security vulnerabilities using LLMs, while some works showed potential, most of the studies we have analyzed in this review showed inconsistent performance and a general tendency towards high false positive rates. The effectiveness of LLMs in this task, seems to be also influenced by the prompting technique adopted. Regarding the ability of fixing vulnerable code, a few studies showed that LLMs can fix simple issues (e.g., memory leaks), but they struggle with complex flaws. Although fine-tuning improves LLMs abilities to fix code, such performance can be achieved only on vulnerabilities for which LLMs have been trained for.

Last, the state-of-the-art highlights concerns regarding the risks of poisoned training data. Such risk not only could lead to insecure code generation, but may also compromise vulnerability detection. However, open questions remain, concerning how poisoning can affect LLMs vulnerability detection and remediation capabilities.

References

- [1] [n. d.]. Checkmarx. <https://www.checkmarx.com/>. Accessed: 2024-09-11.
- [2] [n. d.]. FlawFinder. <http://www.dwheeler.com/flawfinder>. Accessed: 2024-09-11.
- [3] [n. d.]. GitHub - Let's build from here. <https://github.com/>. Accessed: 2024-10-25.
- [4] [n. d.]. Hugging Face - The AI community building the future. <https://huggingface.co/>. Accessed: 2024-10-25.
- [5] [n. d.]. OpenAI ChatGPT. <https://openai.com/chatgpt>. Accessed: 2024-06-10.
- [6] 2024. GitHub Copilot - Your AI pair programmer. <https://github.blog/news-insights/product-news/github-copilot-x-the-ai-powered-developer-experience/>. Accessed: 2024-10-14.
- [7] Hojjat Aghakhani, Wei Dai, Andre Manoel, Xavier Fernandes, Anant Kharkar, Christopher Kruegel, Giovanni Vigna, David Evans, Ben Zorn, and Robert Sim. 2024. Trojanpuzzle: Covertly poisoning code-suggestion models. In *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, 1122–1140.
- [8] Mansour Alqarni and Akramul Azim. 2022. Low Level Source Code Vulnerability Detection Using Advanced BERT Language Model.. In *Canadian AI*.
- [9] Owura Asare, Meiyappan Nagappan, and N Asokan. 2023. Is github's copilot as bad as humans at introducing vulnerabilities in code? *Empirical Software Engineering* 28, 6 (2023), 129.
- [10] Suriya Ganesh Ayyamperumal and Limin Ge. 2024. Current state of LLM Risks and AI Guardrails. *arXiv preprint arXiv:2406.12934* (2024).
- [11] Johannes Bader, Andrew Scott, Michael Pradel, and Satish Chandra. 2019. Getafix: Learning to fix bugs automatically. *Proceedings of the ACM on Programming Languages* 3, OOPSLA (2019), 1–27.
- [12] Jaehyeon Bae, Seoryeong Kwon, and Seunghwan Myeong. 2024. Enhancing Software Code Vulnerability Detection Using GPT-4o and Claude-3.5 Sonnet: A Study on Prompt Engineering Techniques. *Electronics* 13, 13 (2024), 2657.

- [13] Atieh Bakhshandeh, Abdalsamad Keramatfar, Amir Norouzi, and Mohammad M Chekidehkhoun. 2023. Using ChatGPT as a Static Application Security Testing Tool. *ISecure* 15, 3 (2023).
- [14] Mahmoud Basharat and Marwan Omar. 2024. SecuGuard: Leveraging pattern-exploiting training in language models for advanced software vulnerability detection. *International Journal of Mathematics and Computer in Engineering* (2024).
- [15] Berkay Berabi, Alexey Gronskey, Veselin Raychev, Gishor Sivanrupan, Victor Chibotaru, and Martin Vechev. 2024. Deepcode AI fix: Fixing security vulnerabilities with large language models. *arXiv preprint arXiv:2402.13291* (2024).
- [16] Lucas Beyer, Xiaohua Zhai, Amélie Royer, Larisa Markeeva, Rohan Anil, and Alexander Kolesnikov. 2022. Knowledge distillation: A good teacher is patient and consistent. In *Proceedings of the IEEE/CVF conference on computer vision and pattern recognition*. 10925–10934.
- [17] Paul E Black et al. 2017. Sard: A software assurance reference dataset. In *Anonymous Cybersecurity Innovation Forum*., Vol. 85.
- [18] Idan A Blank. 2023. What are large language models supposed to model? *Trends in Cognitive Sciences* (2023).
- [19] Orçun Çetin, Emre Ekmekcioglu, Budi Arief, and Julio Hernandez-Castro. 2024. An Empirical Evaluation of Large Language Models in Static Code Analysis for PHP Vulnerability Detection. *Journal of Universal Computer Science* (2024).
- [20] Saikat Chakraborty, Rahul Krishna, Yangruibo Ding, and Baishakhi Ray. 2021. Deep learning based vulnerability detection: Are we there yet? *IEEE Transactions on Software Engineering* 48, 9 (2021), 3280–3296.
- [21] Chong Chen, Jianzhong Su, Jiachi Chen, Yanlin Wang, Tingting Bi, Jianxing Yu, Yanli Wang, Xingwei Lin, Ting Chen, and Zibin Zheng. 2024. When ChatGPT Meets Smart Contract Vulnerability Detection: How Far Are We? *ACM Trans. Softw. Eng. Methodol.* (Nov. 2024). doi:10.1145/3702973 Just Accepted.
- [22] Yuchen Chen, Weisong Sun, Chunrong Fang, Zhenpeng Chen, Yifei Ge, Tingxu Han, Quanjun Zhang, Yang Liu, Zhenyu Chen, and Baowen Xu. 2024. Security of Language Models for Code: A Systematic Literature Review. *arXiv preprint arXiv:2410.15631* (2024).
- [23] Zimin Chen, Steve Kommrusch, and Martin Monperrus. 2022. Neural transfer learning for repairing security vulnerabilities in c code. *IEEE Transactions on Software Engineering* 49, 1 (2022), 147–165.
- [24] Kyunghyun Cho, Bart van Merriënboer, Caglar Gulcehre, Dzmitry Bahdanau, Fethi Bougares, Holger Schwenk, and Yoshua Bengio. 2014. Learning Phrase Representations using RNN Encoder–Decoder for Statistical Machine Translation. In *Proceedings of the 2014 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, Alessandro Moschitti, Bo Pang, and Walter Daelemans (Eds.), Association for Computational Linguistics, Doha, Qatar, 1724–1734. doi:10.3115/v1/D14-1179
- [25] Domenico Cotroni, Cristina Improtà, Pietro Liguori, and Roberto Natella. 2024. Vulnerabilities in ai code generators: Exploring targeted data poisoning attacks. In *Proceedings of the 32nd IEEE/ACM International Conference on Program Comprehension*. 280–292.
- [26] David de Fitero-Dominguez, Eva Garcia-Lopez, Antonio Garcia-Cabot, and Jose-Javier Martinez-Herraz. 2024. Enhanced automated code vulnerability repair using large language models. *Engineering Applications of Artificial Intelligence* 138 (2024), 109291. doi:10.1016/j.engappai.2024.109291
- [27] Yangruibo Ding, Yanjun Fu, Omniyyah Ibrahim, Chawin Sitawarin, Xinyun Chen, Basel Alomair, David Wagner, Baishakhi Ray, and Yizheng Chen. 2025. Vulnerability Detection with Code Language Models: How Far Are We? . In *2025 IEEE/ACM 47th International Conference on Software Engineering (ICSE)*. IEEE Computer Society, Los Alamitos, CA, USA, 469–481. doi:10.1109/ICSE55347.2025.00038
- [28] Yangruibo Ding, Sahil Suneja, Yunhui Zheng, Jim Laredo, Alessandro Morari, Gail Kaiser, and Baishakhi Ray. 2022. VELVET: a noVel Ensemble Learning approach to automatically locate Vulnerable Statements. In *2022 IEEE International Conference on Software Analysis, Evolution and Reengineering (SANER)*. IEEE, 959–970.
- [29] Thomas Dohmke. 2024. GitHub Copilot X: The AI-powered developer experience. <https://github.blog/news-insights/product-news/github-copilot-x-the-ai-powered-developer-experience/>. Accessed: 2024-10-14.
- [30] Ran Elgedawy, John Sadik, Senjuti Dutta, Anuj Gautam, Konstantinos Georgiou, Farzin Gholamrezae, Fujiao Ji, Kyungchan Lim, Qian Liu, and Scott Ruoti. 2024. Occasionally Secure: A Comparative Analysis of Code Generation Assistants. *arXiv preprint arXiv:2402.00689* (2024).
- [31] Chongzhou Fang, Ning Miao, Shaurya Srivastav, Jialin Liu, Ruoyu Zhang, Ruijie Fang, Ryan Tsang, Najmeh Nazari, Han Wang, Houman Homayoun, et al. 2024. Large Language Models for Code Analysis: Do {LLMs} Really Do Their Job?. In *33rd USENIX Security Symposium (USENIX Security 24)*. 829–846.
- [32] Josselin Feist, Gustavo Grieco, and Alex Groce. 2019. Slither: a static analysis framework for smart contracts. In *2019 IEEE/ACM 2nd International Workshop on Emerging Trends in Software Engineering for Blockchain (WETSEB)*. IEEE, 8–15.
- [33] Michael Fu and Chakkrit Tantithamthavorn. 2022. Linevul: A transformer-based line-level vulnerability prediction. In *Proceedings of the 19th International Conference on Mining Software Repositories*. 608–620.
- [34] Michael Fu, Chakkrit Tantithamthavorn, Trung Le, Van Nguyen, and Dinh Phung. 2022. VulRepair: a T5-based automated software vulnerability repair. In *Proceedings of the 30th ACM joint european software engineering conference and symposium on the foundations of software engineering*. 935–947.
- [35] Yujia Fu, Peng Liang, Amjed Tahir, Zengyang Li, Mojtaba Shahin, and Jiaxin Yu. 2023. Security weaknesses of copilot generated code in github. *arXiv preprint arXiv:2310.02059* (2023).
- [36] Zeyu Gao, Hao Wang, Yuchen Zhou, Wenyu Zhu, and Chao Zhang. 2023. How far have we gone in vulnerability detection using large language models. *arXiv preprint arXiv:2311.12420* (2023).

- [37] Jianian Gong, Nachuan Duan, Ziheng Tao, Zhaohui Gong, Yuan Yuan, and Minlie Huang. 2024. How Well Do Large Language Models Serve as End-to-End Secure Code Producers? *arXiv preprint arXiv:2408.10495* (2024).
- [38] Yuejun Guo, Constantinos Patsakis, Qiang Hu, Qiang Tang, and Fran Casino. 2024. Outside the Comfort Zone: Analysing LLM Capabilities in Software Vulnerability Detection. In *European Symposium on Research in Computer Security*. Springer, 271–289.
- [39] Hossein Hajipour, Keno Hassler, Thorsten Holz, Lea Schönherr, and Mario Fritz. 2024. CodeLMsec Benchmark: Systematically Evaluating and Finding Security Vulnerabilities in Black-Box Code Language Models. In *2024 IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*. IEEE, 684–709.
- [40] Sivana Hamer, Marcelo d’Amorim, and Laurie Williams. 2024. Just another copy and paste? Comparing the security vulnerabilities of ChatGPT generated code and StackOverflow answers. In *2024 IEEE Security and Privacy Workshops (SPW)*. IEEE Computer Society, Los Alamitos, CA, USA, 87–94. doi:10.1109/SPW63631.2024.00014
- [41] Andreas Happe and Jürgen Cito. 2023. Getting pwn’d by ai: Penetration testing with large language models. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 2082–2086.
- [42] Jingxuan He and Martin Vechev. 2023. Large language models for code: Security hardening and adversarial testing. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*. 1865–1879.
- [43] Jingxuan He, Mark Vero, Gabriela Krasnopolska, and Martin Vechev. 2024. Instruction Tuning for Secure Code Generation. In *Proceedings of the 41st International Conference on Machine Learning (Proceedings of Machine Learning Research, Vol. 235)*, Ruslan Salakhutdinov, Zico Kolter, Katherine Heller, Adrian Weller, Nuria Oliver, Jonathan Scarlett, and Felix Berkenkamp (Eds.). PMLR, 18043–18062. <https://proceedings.mlr.press/v235/he24k.html>
- [44] Xinyi Hou, Yanjie Zhao, Yue Liu, Zhou Yang, Kailong Wang, Li Li, Xiapu Luo, David Lo, John Grundy, and Haoyu Wang. 2023. Large language models for software engineering: A systematic literature review. *ACM Transactions on Software Engineering and Methodology* (2023).
- [45] Sihao Hu, Tiansheng Huang, Fatih İlhan, Selim Furkan Tekin, and Ling Liu. 2023. Large language model-powered smart contract vulnerability detection: New perspectives. In *2023 5th IEEE International Conference on Trust, Privacy and Security in Intelligent Systems and Applications (TPS-ISA)*. IEEE, 297–306.
- [46] Majeed Kazemitabaar, Xinying Hou, Austin Henley, Barbara Jane Ericson, David Weintrop, and Tovi Grossman. 2024. How Novices Use LLM-based Code Generators to Solve CS1 Coding Tasks in a Self-Paced Learning Environment. In *Proceedings of the 23rd Koli Calling International Conference on Computing Education Research (<conf-loc>, <city>Koli</city>, <country>Finland</country>, </conf-loc>)* (Koli Calling ’23). Association for Computing Machinery, New York, NY, USA, Article 3, 12 pages. doi:10.1145/3631802.3631806
- [47] Jacob Devlin Ming-Wei Chang Kenton and Lee Kristina Toutanova. 2019. Bert: Pre-training of deep bidirectional transformers for language understanding. In *Proceedings of naacL-HLT*, Vol. 1. Minneapolis, Minnesota, 2.
- [48] Raphaël Khoury, Anderson R Avila, Jacob Brunelle, and Baba Mamadou Camara. 2023. How secure is code generated by chatgpt?. In *2023 IEEE International Conference on Systems, Man, and Cybernetics (SMC)*. IEEE, 2445–2451.
- [49] Sung Yong Kim, Zhiyu Fan, Yannic Noller, and Abhik Roychoudhury. 2024. Codexity: Secure AI-assisted Code Generation. *arXiv preprint arXiv:2405.03927* (2024).
- [50] Takeshi Kojima, Shixiang (Shane) Gu, Machel Reid, Yutaka Matsuo, and Yusuke Iwasawa. 2022. Large Language Models are Zero-Shot Reasoners. In *Advances in Neural Information Processing Systems*, S. Koyejo, S. Mohamed, A. Agarwal, D. Belgrave, K. Cho, and A. Oh (Eds.), Vol. 35. Curran Associates, Inc., 22199–22213. https://proceedings.neurips.cc/paper_files/paper/2022/file/8bb0d291acd4acf06ef112099c16f326-Paper-Conference.pdf
- [51] Ummay Kulsum, Haotian Zhu, Bowen Xu, and Marcelo d’Amorim. 2024. A Case Study of LLM for Automated Vulnerability Repair: Assessing Impact of Reasoning and Patch Validation Feedback (*AIware 2024*). Association for Computing Machinery, New York, NY, USA, 103–111. doi:10.1145/3664646.3664770
- [52] Tan Khang Le, Saba Alimadadi, and Steven Y Ko. 2024. A Study of Vulnerability Repair in JavaScript Programs with Large Language Models. In *Companion Proceedings of the ACM on Web Conference 2024*. 666–669.
- [53] Haonan Li, Yu Hao, Yizhuo Zhai, and Zhiyun Qian. 2023. Assisting static analysis with large language models: A chatgpt experiment. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 2107–2111.
- [54] Haonan Li, Yu Hao, Yizhuo Zhai, and Zhiyun Qian. 2024. Enhancing Static Analysis for Practical Bug Detection: An LLM-Integrated Approach. *Proceedings of the ACM on Programming Languages* 8, OOPSLA1 (2024), 474–499.
- [55] Yi Li, Shaohua Wang, and Tien N Nguyen. 2021. Vulnerability detection with fine-grained interpretations. In *Proceedings of the 29th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 292–303.
- [56] Ziyang Li, Saikat Dutta, and Mayur Naik. 2024. LLM-Assisted Static Analysis for Detecting Security Vulnerabilities. *arXiv preprint arXiv:2405.17238* (2024).
- [57] Zhen Li, Deqing Zou, Shouhuai Xu, Xinyu Ou, Hai Jin, Sujuan Wang, Zhijun Deng, and Yuyi Zhong. 2018. Vuldeepecker: A deep learning-based system for vulnerability detection. In *Proceedings of the 25th Annual Network and Distributed System Security Symposium (NDSS’18)*. <https://doi.org/10.14722/ndss.2018.23158>

- [58] Peiyu Liu, Junming Liu, Lirong Fu, Kangjie Lu, Yifan Xia, Xuhong Zhang, Wenzhi Chen, Haiqin Weng, Shouling Ji, and Wenhai Wang. 2024. Exploring ChatGPT’s Capabilities on Vulnerability Management. In *33rd USENIX Security Symposium (USENIX Security 24)*. 811–828.
- [59] Peng Liu, He Wang, Chen Zheng, and Yuqing Zhang. 2024. Prompt Fix: Vulnerability Automatic Repair Technology Based on Prompt Engineering. In *2024 International Conference on Computing, Networking and Communications (ICNC)*. 116–120. doi:10.1109/ICNC59896.2024.10556123
- [60] Yu Liu, Lang Gao, Mingxin Yang, Yu Xie, Ping Chen, Xiaojin Zhang, and Wei Chen. 2024. VulDetectBench: Evaluating the Deep Capability of Vulnerability Detection with Large Language Models. *arXiv preprint arXiv:2406.07595* (2024).
- [61] Zhijie Liu, Yutian Tang, Xiapu Luo, Yuming Zhou, and Liang Feng Zhang. 2024. No need to lift a finger anymore? Assessing the quality of code generation by ChatGPT. *IEEE Transactions on Software Engineering* (2024).
- [62] Ziyang Luo, Can Xu, Pu Zhao, Qingfeng Sun, Xiubo Geng, Wenxiang Hu, Chongyang Tao, Jing Ma, Qingwei Lin, and Daxin Jiang. 2024. WizardCoder: Empowering Code Large Language Models with Evol-Instruct. In *The Twelfth International Conference on Learning Representations*. <https://openreview.net/forum?id=UnUwSlgK5W>
- [63] Qiheng Mao, Zhenhao Li, Xing Hu, Kui Liu, Xin Xia, and Jianling Sun. 2024. Towards Effectively Detecting and Explaining Vulnerabilities Using Large Language Models. *arXiv preprint arXiv:2406.09701* (2024).
- [64] Noble Saji Mathews, Yelizaveta Brus, Yousra Aafer, Mei Nagappan, and Shane McIntosh. 2024. Llbzpeky: Leveraging large language models for vulnerability detection. *arXiv preprint arXiv:2401.01269* (2024).
- [65] MITRE Corporation. [n.d.]. Common Weakness Enumeration (CWE). <https://cwe.mitre.org/> Accessed: 2024-07-31.
- [66] MITRE Corporation. 2023. CWE Top 25 Most Dangerous Software Weaknesses: 2023. https://cwe.mitre.org/top25/archive/2023/2023_top25_list.html Accessed: 2024-07-31.
- [67] Mohammad Mahdi Mohajer, Reem Aleithan, Nima Shiri Harzevili, Moshi Wei, Alvine Boaye Belle, Hung Viet Pham, and Song Wang. 2024. Effectiveness of ChatGPT for Static Analysis: How Far Are We?. In *Proceedings of the 1st ACM International Conference on AI-Powered Software*. 151–160.
- [68] Ahmad Mohsin, Helge Janicke, Adrian Wood, Iqbal H Sarker, Leandros Maglaras, and Naeem Janjua. 2024. Can We Trust Large Language Models Generated Code? A Framework for In-Context Learning, Security Patterns, and Code Evaluations Across Diverse LLMs. *arXiv preprint arXiv:2406.12513* (2024).
- [69] Claudia Negri-Ribalta, Rémi Geraud-Stewart, Anastasia Sergeeva, and Gabriele Lenzini. 2024. A systematic literature review on the impact of AI models on the security of code generation. *Frontiers in Big Data* 7 (2024), 1386720.
- [70] Chao Ni, Liyu Shen, Xiaodan Xu, Xin Yin, and Shaohua Wang. 2024. Learning-based Models for Vulnerability Detection: An Extensive Study. *arXiv preprint arXiv:2408.07526* (2024).
- [71] Chao Ni, Xin Yin, Kaiwen Yang, Dehai Zhao, Zhenchang Xing, and Xin Xia. 2023. Distinguishing look-alike innocent and vulnerable code by subtle semantic representation learning and explanation. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 1611–1622.
- [72] Erik Nijkamp, Bo Pang, Hiroaki Hayashi, Lifu Tu, Huan Wang, Yingbo Zhou, Silvio Savarese, and Caiming Xiong. 2023. CodeGen: An Open Large Language Model for Code with Multi-Turn Program Synthesis. In *The Eleventh International Conference on Learning Representations*. https://openreview.net/forum?id=iaYcJKpY2B_
- [73] David Noever. 2023. Can large language models find and fix vulnerable software? *arXiv preprint arXiv:2308.10345* (2023).
- [74] Yu Nong, Mohammed Aldeen, Long Cheng, Hongxin Hu, Feng Chen, and Haipeng Cai. 2024. Chain-of-thought prompting of large language models for discovering and fixing software vulnerabilities. *arXiv preprint arXiv:2402.17230* (2024).
- [75] Yu Nong, Haoran Yang, Long Cheng, Hongxin Hu, and Haipeng Cai. 2024. Automated Software Vulnerability Patching using Large Language Models. *arXiv preprint arXiv:2408.13597* (2024).
- [76] Sanghak Oh, Kiho Lee, Seonhye Park, Doowon Kim, and Hyoungshick Kim. 2024. Poisoned chatgpt finds work for idle hands: Exploring developers’ coding practices with insecure suggestions from poisoned ai models. In *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, 1141–1159.
- [77] Marwan Omar and Darrell Burrell. 2023. From text to threats: A language model approach to software vulnerability detection. *International Journal of Mathematics and Computer in Engineering* (2023).
- [78] Omer Said Ozturk, Emre Ekmekcioglu, Orcun Cetin, Budi Arief, and Julio Hernandez-Castro. 2023. New Tricks to Old Codes: Can AI Chatbots Replace Static Code Analysis Tools? (*EICC ’23*). Association for Computing Machinery, New York, NY, USA, 13–18. doi:10.1145/3590777.3590780
- [79] Rajshakhar Paul, Asif Kamal Turzo, and Amiangshu Bosu. 2021. Why security defects go unnoticed during code reviews? a case-control study of the chromium os project. In *2021 IEEE/ACM 43rd International Conference on Software Engineering (ICSE)*. IEEE, 1373–1385.
- [80] Hammond Pearce, Baleegh Ahmad, Benjamin Tan, Brendan Dolan-Gavitt, and Ramesh Karri. 2022. Asleep at the keyboard? assessing the security of github copilot’s code contributions. In *2022 IEEE Symposium on Security and Privacy (SP)*. IEEE, 754–768.
- [81] Hammond Pearce, Benjamin Tan, Baleegh Ahmad, Ramesh Karri, and Brendan Dolan-Gavitt. 2023. Examining Zero-Shot Vulnerability Repair with Large Language Models. In *2023 IEEE Symposium on Security and Privacy (SP)*. IEEE Computer Society, 2339–2356.

- [82] Elijah Pelofske, Vincent Urias, and Lorie M Liebrock. 2024. Automated Software Vulnerability Static Code Analysis Using Generative Pre-Trained Transformer Models. *arXiv preprint arXiv:2408.00197* (2024).
- [83] Neil Perry, Megha Srivastava, Deepak Kumar, and Dan Boneh. 2023. Do users write more insecure code with AI assistants?. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*. 2785–2799.
- [84] Kai Petersen, Sairam Vakkalanka, and Ludwik Kuzniarz. 2015. Guidelines for conducting systematic mapping studies in software engineering: An update. *Information and Software Technology* 64 (2015), 1–18. doi:10.1016/j.infsof.2015.03.007
- [85] Moumita Das Purba, Arpita Ghosh, Benjamin J Radford, and Bill Chu. 2023. Software vulnerability detection using large language models. In *2023 IEEE 34th International Symposium on Software Reliability Engineering Workshops (ISSREW)*. IEEE, 112–119.
- [86] Md Fazle Rabbi, Arifa I Champa, Minhaz F Zibran, and Md Rakibul Islam. 2024. AI writes we analyze: The ChatGPT python code saga. In *Proceedings of ACM International Conference on Mining Software Repositories (MSR)*.
- [87] Gustavo Sandoval, Hammond Pearce, Teo Nys, Ramesh Karri, Siddharth Garg, and Brendan Dolan-Gavitt. 2023. Lost at c: A user study on the security implications of large language model code assistants. In *32nd USENIX Security Symposium (USENIX Security 23)*. 2205–2222.
- [88] Roei Schuster, Congzheng Song, Eran Tromer, and Vitaly Shmatikov. 2021. You autocomplete me: Poisoning vulnerabilities in neural code completion. In *30th USENIX Security Symposium (USENIX Security 21)*. 1559–1575.
- [89] Alexey Shestov, Anton Cheshkov, Rodion Levichev, Ravil Mussabayev, Pavel Zadorozhny, Evgeny Maslov, Chibirev Vadim, and Egor Bulychev. 2024. Finetuning large language models for vulnerability detection. *arXiv preprint arXiv:2401.17010* (2024).
- [90] Mohammed Latif Siddiq, Joanna Cecilia da Silva Santos, Sajith Devareddy, and Anna Muller. 2024. SALLM: Security Assessment of Generated Code. In *Proceedings of the 39th IEEE/ACM International Conference on Automated Software Engineering Workshops (Sacramento, CA, USA) (ASEW '24)*. Association for Computing Machinery, New York, NY, USA, 54–65. doi:10.1145/3691621.3694934
- [91] Mohammed Latif Siddiq and Joanna CS Santos. 2022. SecurityEval dataset: mining vulnerability examples to evaluate machine learning-based code generation techniques. In *Proceedings of the 1st International Workshop on Mining Software Repositories Applications for Privacy and Security*. 29–33.
- [92] Benjamin Steenhoek, Md Mahbubur Rahman, Monoshi Kumar Roy, Mirza Sanjida Alam, Earl T Barr, and Wei Le. 2024. A Comprehensive Study of the Capabilities of Large Language Models for Vulnerability Detection. *arXiv preprint arXiv:2403.17218* (2024).
- [93] André Storhaug, Jingyue Li, and Tianyuan Hu. 2023. Efficient avoidance of vulnerabilities in auto-completed smart contract code using vulnerability-constrained decoding. In *2023 IEEE 34th International Symposium on Software Reliability Engineering (ISSRE)*. IEEE, 683–693.
- [94] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Haijun Wang, Zhengzi Xu, Xiaofei Xie, and Yang Liu. 2024. Gptscan: Detecting logic vulnerabilities in smart contracts by combining gpt with program analysis. In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering*. 1–13.
- [95] Karl Tamberg and Hayretudin Bahsi. 2024. Harnessing Large Language Models for Software Vulnerability Detection: A Comprehensive Benchmarking Study. *arXiv preprint arXiv:2405.15614* (2024).
- [96] Chandra Thapa, Seung Ick Jang, Muhammad Ejaz Ahmed, Seyit Camtepe, Josef Pieprzyk, and Surya Nepal. 2022. Transformer-based language models for software vulnerability detection. In *Proceedings of the 38th Annual Computer Security Applications Conference*. 481–496.
- [97] Norbert Tihanyi, Tamas Bisztray, Mohamed Amine Ferrag, Ridhi Jain, and Lucas C Cordeiro. 2024. Do neutral prompts produce insecure code? formai-v2 dataset: Labelling vulnerabilities in code generated by large language models. *arXiv preprint arXiv:2404.18353* (2024).
- [98] Rebeka Tóth, Tamas Bisztray, and László Erdődi. 2024. LLMs in Web Development: Evaluating LLM-Generated PHP Code Unveiling Vulnerabilities and Limitations. In *Computer Safety, Reliability, and Security. SAFECOMP 2024 Workshops*, Andrea Ceccarelli, Mario Trapp, Andrea Bondavalli, Erwin Schoitsch, Barbara Gallina, and Friedemann Bitsch (Eds.). Springer Nature Switzerland, Cham, 425–437.
- [99] Hugo Touvron, Thibaut Lavril, Gautier Izacard, Xavier Martinet, Marie-Anne Lachaux, Timothée Lacroix, Baptiste Rozière, Naman Goyal, Eric Hambro, Faisal Azhar, et al. 2023. Llama: Open and efficient foundation language models. *arXiv preprint arXiv:2302.13971* (2023).
- [100] Saad Ullah, Mingji Han, Saurabh Pujar, Hammond Pearce, Ayse Coskun, and Gianluca Stringhini. 2024. LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks. In *IEEE Symposium on Security and Privacy*.
- [101] Zhilong Wang, Lan Zhang, Chen Cao, Nanqing Luo, Xinzhi Luo, and Peng Liu. 2024. How Does Naming Affect LLMs on Code Analysis Tasks? *arXiv:2307.12488 [cs.CR]* <https://arxiv.org/abs/2307.12488>
- [102] Sheng Wen, Mohammad Sayad Haghighi, Chao Chen, Yang Xiang, Wanlei Zhou, and Weijia Jia. 2015. A Sword with Two Edges: Propagation Studies on Both Positive and Negative Information in Online Social Networks. *IEEE Transactions on Computers* 64, 3 (2015), 640–653. doi:10.1109/TC.2013.2295802

- [103] Xin-Cheng Wen, Cuiyun Gao, Shuzheng Gao, Yang Xiao, and Michael R Lyu. 2024. SCALE: Constructing Structured Natural Language Comment Trees for Software Vulnerability Detection. In *Proceedings of the 33rd ACM SIGSOFT International Symposium on Software Testing and Analysis*. 235–247.
- [104] Xin-Cheng Wen, Xincheng Wang, Yujia Chen, Ruida Hu, David Lo, and Cuiyun Gao. 2024. Vuleval: Towards repository-level evaluation of software vulnerability detection. *arXiv preprint arXiv:2404.15596* (2024).
- [105] Yi Wu, Nan Jiang, Hung Viet Pham, Thibaud Lutellier, Jordan Davis, Lin Tan, Petr Babkin, and Sameena Shah. 2023. How effective are neural networks for fixing security vulnerabilities. In *Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis*. 1282–1294.
- [106] HanXiang Xu, ShenAo Wang, Ningke Li, Yanjie Zhao, Kai Chen, Kailong Wang, Yang Liu, Ting Yu, and HaoYu Wang. 2024. Large language models for cyber security: A systematic literature review. *arXiv preprint arXiv:2405.04760* (2024).
- [107] Shenao YAN, Shen WANG, Yue DUAN, Hanbin HONG, Kiho LEE, Doowon KIM, and Yuan HONG. 2024. An LLM-assisted easy-to-trigger poisoning attack on code completion models: Injecting disguised vulnerabilities against strong detection. Usenix.
- [108] Yanjing Yang, Xin Zhou, Runfeng Mao, Jinwei Xu, Lanxin Yang, Yu Zhang, Haifeng Shen, and He Zhang. 2025. DLAP: A Deep Learning Augmented Large Language Model Prompting framework for software vulnerability detection. *Journal of Systems and Software* 219 (2025), 112234. doi:10.1016/j.jss.2024.112234
- [109] Shunyu Yao, Dian Yu, Jeffrey Zhao, Izhak Shafran, Tom Griffiths, Yuan Cao, and Karthik Narasimhan. 2024. Tree of thoughts: Deliberate problem solving with large language models. *Advances in Neural Information Processing Systems* 36 (2024).
- [110] Yifan Yao, Jinhao Duan, Kaidi Xu, Yuanfang Cai, Zhibo Sun, and Yue Zhang. 2024. A Survey on Large Language Model (LLM) Security and Privacy: The Good, The Bad, and The Ugly. *High-Confidence Computing* 4, 2 (2024), 100211. doi:10.1016/j.hcc.2024.100211
- [111] Jiaxin Yu, Peng Liang, Yujia Fu, Amjed Tahir, Mojtaba Shahin, Chong Wang, and Yangxiao Cai. 2024. Security code review by LLMs: A deep dive into responses. *arXiv preprint arXiv:2401.16310* (2024).
- [112] Chenyuan Zhang, Hao Liu, Jiutian Zeng, Kejing Yang, Yuhong Li, and Hui Li. 2024. Prompt-enhanced software vulnerability detection using chatgpt. In *Proceedings of the 2024 IEEE/ACM 46th International Conference on Software Engineering: Companion Proceedings*. 276–277.
- [113] Jie Zhang, Haoyu Bu, Hui Wen, Yu Chen, Lun Li, and Hongsong Zhu. 2024. When LLMs Meet Cybersecurity: A Systematic Literature Review. *arXiv preprint arXiv:2405.03644* (2024).
- [114] Jian Zhang, Shangqing Liu, Xu Wang, Tianlin Li, and Yang Liu. 2023. Learning to Locate and Describe Vulnerabilities. In *2023 38th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. IEEE, 332–344.
- [115] Jian Zhang, Chong Wang, Anran Li, Weisong Sun, Cen Zhang, Wei Ma, and Yang Liu. 2024. An Empirical Study of Automated Vulnerability Localization with Large Language Models. *arXiv preprint arXiv:2404.00287* (2024).
- [116] Jian Zhang, Xu Wang, Hongyu Zhang, Hailong Sun, Xudong Liu, Chunming Hu, and Yang Liu. 2023. Detecting condition-related bugs with control flow graph neural network. In *Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis*. 1370–1382.
- [117] Lan Zhang, Qingtian Zou, Anoop Singhal, Xiaoyan Sun, and Peng Liu. 2024. Evaluating Large Language Models for Real-World Vulnerability Repair in C/C++ Code. In *Proceedings of the 10th ACM International Workshop on Security and Privacy Analytics*. 49–58.
- [118] Xinyu Zhang, Siddharth Muralee, Sourag Cherupattamoolayil, and Aravind Machiry. 2024. On the effectiveness of large language models for github workflows. In *Proceedings of the 19th International Conference on Availability, Reliability and Security*. 1–14.
- [119] Xin Zhou, Sicong Cao, Xiaobing Sun, and David Lo. 2024. Large Language Model for Vulnerability Detection and Repair: Literature Review and the Road Ahead. *ACM Trans. Softw. Eng. Methodol.* (Dec. 2024). doi:10.1145/3708522 Just Accepted.
- [120] Xin Zhou, Kisub Kim, Bowen Xu, DongGyun Han, and David Lo. 2024. Large Language Model as Synthesizer: Fusing Diverse Inputs for Better Automatic Vulnerability Repair. *arXiv preprint arXiv:2401.15459* (2024).
- [121] Xin Zhou, Duc-Manh Tran, Thanh Le-Cong, Ting Zhang, Ivana Clairine Irsan, Joshua Sumarlin, Bach Le, and David Lo. 2024. Comparison of Static Application Security Testing Tools and Large Language Models for Repo-level Vulnerability Detection. *arXiv preprint arXiv:2407.16235* (2024).
- [122] Xin Zhou, Ting Zhang, and David Lo. 2024. Large language model for vulnerability detection: Emerging results and future directions. In *Proceedings of the 2024 ACM/IEEE 44th International Conference on Software Engineering: New Ideas and Emerging Results*. 47–51.
- [123] Yaqin Zhou, Shangqing Liu, Jingkai Siow, Xiaoning Du, and Yang Liu. 2019. Devign: Effective vulnerability identification by learning comprehensive program semantics via graph neural networks. *Advances in neural information processing systems* 32 (2019).